Siber Güvenlik ve Bilişim Hukuku

BVA 2205 · 200 Soruluk Çalışma Kağıdı

MCBÜ Teknik Bilimler MYO · Büyük Veri Analistliği · 2026–2027 Güz

Öğr. Gör. Osman Can Çetlenbik

Bu kitapçık, dersin konularına dayanan 200 hikâyeli ve 5 şıklı sorudan oluşur; 7 bölüme ayrılmıştır.

Her soru kısa bir olayla başlar; cevabı bulmak için olayı dikkatle oku. Şıkları elemeden önce her birinin neden doğru ya da yanlış olabileceğini düşün; emin olamadığın soruları işaretleyip ilgili haftanın sunumundan tekrar et.

İçindekiler

1. HAFTA · Siber Güvenliğe Giriş & CIA Üçlüsü — Soru 1–29
2. HAFTA · Ağ Trafiği Analizi: Wireshark & Nmap — Soru 30–58
3. HAFTA · Kriptografi 101 — Soru 59–87
4. HAFTA · OWASP Top 10 — Bölüm 1 — Soru 88–116
5. HAFTA · OWASP Top 10 — Bölüm 2 — Soru 117–144
6. HAFTA · Kimlik & Erişim Yönetimi — Soru 145–172
7. HAFTA · Endpoint Güvenliği ve Malware Analizi Temelleri — Soru 173–200

1. HAFTA · Siber Güvenliğe Giriş & CIA Üçlüsü

1. Manisa'da bir devlet hastanesinin bilgi işlem biriminde staj yapan Ece, poliklinik sekreterlerinin kullandığı hesapla tüm hastaların tahlil sonuçlarının da açılabildiğini fark ediyor. Kayıtlarda herhangi bir değişiklik yok ve sistem kesintisiz çalışıyor. Bu durumda CIA üçlüsünün hangi ilkesi doğrudan risk altındadır?

   A) Hesap verebilirlik (Accountability)
   B) İnkâr edilemezlik (Non-repudiation)
   C) Erişilebilirlik (Availability)
   D) Bütünlük (Integrity)
   E) Gizlilik (Confidentiality)

2. Bir kargo firmasının teslimat takip sisteminde, gece yarısı bazı gönderilerin teslim adresleri sessizce değiştirilmiş; sistem normal çalışmaya devam etmiş ve kimse durumu günlerce fark etmemiştir. Adreslerin dışarıya aktarıldığına dair bir iz yoktur. BT sorumlusu Kerem bu olayı CIA üçlüsünde öncelikle hangi ilkenin ihlali olarak raporlamalıdır?

   A) Bütünlük; veri yetkisiz biçimde değiştirilmiştir
   B) Erişilebilirlik; teslimatlar bu yüzden gecikecektir
   C) Gizlilik; adresler kişisel veri niteliğindedir
   D) Erişilebilirlik; sistem saldırı altında çalışmıştır
   E) Gizlilik; olay gece saatinde fark edilmeden yaşanmıştır

3. Salihli'deki bir belediyenin su faturası ödeme portalı, tek sunucudaki SSD'nin arızalanması yüzünden altı saat erişilemez oldu. İncelemede herhangi bir saldırı izi ya da veri sızıntısı bulunmadı. Sistem yöneticisi Hakan'ın bu olaya bakışı hangisi olmalıdır?

   A) Arıza iç kaynaklı olduğu için KVKK kapsamında 72 saat içinde bildirim zorunludur
   B) Saldırı olmasa da erişilebilirlik ihlali yaşanmıştır; yedeklilik ve DRP gözden geçirilmelidir
   C) Saldırı izi olmadığı için bu bir güvenlik olayı sayılmaz, yalnızca bir donanım arızasıdır
   D) Disk bozulduğunda veri değiştiği için olay öncelikle bir bütünlük ihlalidir
   E) Veri sızmadığı için olay yalnızca gizlilik açısından değerlendirilip kapatılmalıdır

4. Kampüs bilgi işlem stajyeri Mert, laboratuvar bilgisayarlarına kurulacak Linux ISO dosyasını bir yansı (mirror) sunucusundan indirdi. Dosyanın yolda değiştirilmediğinden emin olmak istiyor. Hangi adım bu amaca en uygun kontroldür?

   A) ISO'yu AES-256 ile şifreleyip laboratuvar sunucusunda saklamak
   B) ISO'nun SHA-256 özetini hesaplayıp resmî sitedeki değerle karşılaştırmak
   C) Dosya boyutunun sitede yazan boyutla aynı olduğunu kontrol etmek
   D) İndirmeyi başka bir yansıdan tekrarlayıp iki dosyayı açmayı denemek
   E) ISO'yu Base64 ile kodlayıp çıktının okunabilir olduğunu görmek

5. Bir derste hoca, operatör ekranları her şeyi normal gösterirken uranyum santrifüjlerini yöneten PLC kodunun sessizce değiştirildiği ve cihazların zamanla yıprandığı bir vakayı anlatıyor. Anlatılan vaka ve baskın biçimde ihlal edilen ilke hangi seçenekte doğru eşleştirilmiştir?

   A) GitHub DDoS (2018) — Bütünlük
   B) Stuxnet (2010) — Bütünlük
   C) SolarWinds (2020) — Erişilebilirlik
   D) Stuxnet (2010) — Gizlilik
   E) Equifax (2017) — Bütünlük

6. Bir e-ticaret firmasında BT sorumlusu olan Gizem, yönetime yama sürecinin hızlandırılması gerektiğini anlatmak için 147 milyon kişinin kimlik ve adres bilgilerinin sızdığı 2017 Equifax vakasını örnek gösteriyor. Gizem bu vakanın kök nedenini ve baskın ihlal edilen ilkeyi nasıl özetlemelidir?

A) İmzalı bir güncellemeye arka kapı eklendi; baskın ihlal bütünlüktür
B) Memcached amplifikasyonuyla sunucular çökertildi; baskın ihlal erişilebilirliktir
C) Mirai botnet'iyle DNS altyapısı kilitlendi; baskın ihlal erişilebilirliktir
D) Endüstriyel PLC kodu sessizce değiştirildi; baskın ihlal bütünlüktür
E) Yamalanmamış Apache Struts zafiyeti istismar edildi; baskın ihlal gizliliktir

7. Bir meslek yüksekokulunun öğrenci bilgi sistemi, ders kayıt haftasında binlerce ele geçirilmiş cihazdan gelen sahte istek seliyle yanıt veremez hâle geliyor. Sistem yöneticisi Serkan, benzer bir tabloyu 2018 GitHub vakasından hatırlıyor. Bu saldırı türüne karşı sunumda önerilen temel savunma hangisidir?

A) Oturum çerezlerinde HttpOnly ve SameSite kullanımı
B) Veritabanında parametreli sorgu ve en az yetki ilkesi
C) Disk şifreleme ve veri sızıntısı önleme (DLP)
D) Parolaların argon2id ile tuzlanarak saklanması
E) CDN ve anti-DDoS hizmeti, hız sınırlama ve anycast

8. Bir belediyenin kullandığı ağ izleme yazılımının resmî ve dijital olarak imzalı güncellemesine, üretici tarafında bir arka kapı eklendiği ortaya çıkıyor. Belediye sistem yöneticisi Levent durumu 2020 SolarWinds vakasına benzetiyor. Bu olay OWASP Top 10 (2021) listesinde en doğrudan hangi kategoriyle ilişkilidir?

A) A10 Server-Side Request Forgery
B) A03 Injection
C) A05 Security Misconfiguration
D) A08 Software & Data Integrity
E) A01 Broken Access Control

9. Akhisar'daki bir zeytin üreticileri kooperatifinde BT işlerine bakan Derya, muhasebe verilerinin yedekleme planını gözden geçiriyor. Aşağıdaki planlardan hangisi sunumdaki 3-2-1 yedekleme kuralını karşılar?

A) Ofisteki NAS cihazında üç ayrı klasörde tutulan üç ayrı kopya
B) Sunucudaki asıl veri, ofisteki NAS'ta bir kopya ve kurum dışı bulut depoda bir kopya
C) Sunucudaki asıl veri ve kurum dışı bulut depoda tutulan tek bir kopya
D) Sunucudaki asıl veri ve ofisteki NAS cihazında tutulan iki ayrı kopya
E) Sunucudaki asıl veri ve aynı sunucunun ikinci diskinde tutulan iki ayrı kopya

10. Bir özel hastanenin acil servisinde, hasta kayıt ekranına her erişimde üç ayrı doğrulama adımı ve iki dakikalık oturum zaman aşımı getiriliyor. Kısa süre sonra doktorlar kritik anlarda kayıtlara zamanında ulaşamadıklarından şikâyet ediyor. Bu durum CIA üçgeniyle ilgili hangi ilkeyi en iyi örnekler?

A) Erişilebilirlik arttıkça gizlilik de kendiliğinden ve aynı oranda artar
B) Üç ilke bağımsız olduğundan bir kontrol diğer ilkeleri hiç etkilemez
C) Bütünlük ihlal edildiği için kayıtlara artık güvenilemez hâle gelmiştir
D) Çok adımlı doğrulama gizliliği değil yalnızca bütünlüğü korumaya yarar
E) Gizliliği aşırı güçlendirmek erişilebilirliği zayıflatabilir; denge aranmalıdır

11. Bir kafe zincirinin web sitesinin erişim kayıtlarında, kısa sürede binlerce farklı yola yapılan ve hazır bir aracın varsayılan imzasını taşıyan gürültülü istekler görülüyor. Hedef seçimi rastgele görünüyor; istekler yalnızca bilinen eski açıkları deniyor. SOC stajyeri Buse bu tabloya en çok hangi tehdit aktörü profilini yakıştırmalıdır?

A) APT (devlet destekli grup)
B) Kurumsal casus
C) Hacktivist
D) Insider (içeriden tehdit)
E) Script kiddie

12. Bir lojistik firmasından üç ay önce ayrılan bir çalışanın VPN hesabı kapatılmamış. Kayıtlar, bu hesapla gece saatlerinde müşteri listesinin indirildiğini gösteriyor. Bu olay hangi tehdit aktörü türüne örnektir ve sunuma göre bu tür neden “en sinsi” tehdit sayılır?

A) Script kiddie; hazır araçlarla rastgele hedef seçtiği için
B) Insider; meşru bir yetkiyle zaten içeride olduğu için
C) APT; 0-day kullanarak aylarca fark edilmediği için
D) Siber suçlu; veriyi karanlık pazarda satacağı için
E) Hacktivist; ideolojik bir mesaj vermek istediği için

13. Bir savunma sanayii tedarikçisinde yapılan adli incelemede, saldırganların yaklaşık sekiz ay boyunca ağda fark edilmeden kaldığı, daha önce bilinmeyen bir zafiyetten (0-day) yararlandıkları ve hedefli olarak tasarım dosyalarını topladıkları anlaşılıyor. Bu saldırgan profili en çok hangisine uyar?

A) Fidye odaklı siber suçlu
B) Hacktivist
C) Insider (içeriden tehdit)
D) APT (devlet destekli grup)
E) Script kiddie

14. Muhasebe çalışanı Nazlı'ya “Manlsabank Destek” adıyla, hesabının kilitlendiğini bildiren bir e-posta geliyor. E-postadaki bağlantı şudur: https://manlsabank-guvenlik.tr-login.xyz/dogrula?ref=8821. Bu bağlantıyla ilgili en doğru teknik tespit hangisidir?

A) Asıl alan adı tr-login.xyz'dir; banka adı yalnızca alt alan adı olarak eklenmiştir
B) Alan adında “guvenlik” kelimesi geçtiği için bankanın güvenlik birimine aittir
C) Bağlantı manlsabank.com alanının bir alt sayfası olduğu için güvenilirdir
D) Bağlantıdaki ref=8821 değeri bankanın müşteri numarası olduğu için gerçektir
E) Adres https ile başladığı için bağlantı bankaya aittir ve güvenle açılabilir

15. Kampüs BT birimi, farkındalık eğitiminde öğrencilere gelen sahte bir e-postayı inceliyor: gönderim saati 03:47, konu satırında “24 saat içinde doğrulayın”, metinde “müşteriimiz” yazım hatası ve “hesabınız KALICI olarak kapatılacaktır” uyarısı var. Bu e-postada saldırganın öncelikle dayandığı şey nedir?

A) Şifresiz HTTP trafiğinin pasif olarak dinlenmesi
B) E-posta sunucusundaki bir SQL injection açığı
C) Tarayıcıdaki yamalanmamış bir yazılım zafiyeti
D) Ekteki bir dosyaya gizlenmiş Office makrosu
E) Korku ve aciliyet gibi duygusal baskı unsurları

16. Yetkili bir sızma testi kapsamında Turgutlu'daki bir KOBİ'nin sunucusu için hazırlanan raporda şu satırlar var: “21/tcp open ftp vsftpd 2.3.4”, “22/tcp open ssh OpenSSH 7.4”, “80/tcp open http Apache httpd 2.4.6”. Raporu okuyan BT sorumlusu Okan'ın önceliklendirmesi gereken ilk iş hangisidir?

A) Apache'nin 80 numaralı portunu 8080'e taşıyarak servisi gözden saklamak
B) Portları olduğu gibi bırakıp yalnızca antivirüs taramasını sıklaştırmak
C) SSH servisini kapatıp sunucuya bundan sonra yalnızca Telnet ile bağlanmak
D) Raporu bekletip taramanın -sU ile UDP sonuçlarını tamamlamasını beklemek
E) Bilinen arka kapısı olan vsftpd 2.3.4 servisini kapatmak ya da güncellemek

17. SOC stajyeri İrem, sunumdaki pratik görevi yapıyor: bir fidye yazılımı senaryosu çizip defense in depth modelinin beş halkasının her birine bir kontrol yerleştiriyor. Aşağıdaki katman–kontrol eşleştirmelerinden hangisi sunumdaki listeye uygundur?

A) Veri katmanı — VLAN ayrımı ve IDS/IPS
B) Host katmanı — EDR, sertleştirme ve yama yönetimi
C) Uygulama katmanı — CCTV ve mantrap geçişi
D) Fiziksel katman — WAF ve SAST/DAST testleri
E) Ağ katmanı — disk şifreleme ve tokenization

18. Bir e-ticaret sitesinin yöneticisi toplantıda “Önümüzde güçlü bir güvenlik duvarı var; sunuculara ve uygulamaya ayrıca önlem almamız gereksiz” diyor. Stajyer Kaan bu görüşe defense in depth ilkesiyle itiraz ediyor. Kaan'ın gerekçesi en iyi hangisidir?

A) Katmanlı savunma yalnızca kamu kurumları için yasal olarak zorunludur
B) Güvenlik duvarları yalnızca fiziksel saldırılara karşı koruma sağlayabilir
C) Güvenlik duvarı varken uygulama katmanında saldırı teknik olarak imkânsızdır
D) Saldırgan bir katmanı aşarsa sıradaki katmanın onu durdurabilmesi gerekir
E) Tek ve güçlü bir kontrol, birden çok kontrolden her zaman daha pahalıdır

19. Bir kargo firmasının iki deposu arasında her gece yüzlerce gigabaytlık arşiv aktarılacak. Ağ uzmanı Burak hızlı bir şifreleme yöntemi seçiyor, ancak her iki tarafın da aynı anahtarı kullanacağını ve bu anahtarı karşı depoya güvenle ulaştırmanın ayrı bir sorun olduğunu biliyor. Burak'ın seçtiği yöntem hangisidir?

A) Kriptografik hash (ör. SHA-256)
B) Asimetrik şifreleme (ör. RSA)
C) Base64 kodlama
D) Simetrik şifreleme (ör. AES)
E) Dijital imza (ör. Ed25519)

20. Bir otelin açık misafir Wi-Fi ağında sahte bir erişim noktası (hotspot) kurulduğu ve bazı misafirlerin trafiğinin bu noktadan geçerek dinlendiği, hatta değiştirildiği anlaşılıyor. Bu saldırı türü ve sunumda belirtilen etkilediği ilkeler hangi seçenekte doğru verilmiştir?

A) SQL Injection — gizlilik ve erişilebilirlik
B) MITM — yalnızca erişilebilirlik
C) Zero-day — yalnızca bütünlük
D) MITM — gizlilik ve bütünlük
E) DDoS — erişilebilirlik

21. Bir muhasebe bürosunun dosyaları bir sabah şifrelenmiş hâlde bulunuyor; saldırganlar hem çözme anahtarı için kripto para istiyor hem de ödeme yapılmazsa müşteri dosyalarını internette yayımlamakla tehdit ediyor. Bu “çift gasp” tablosuna karşı sunumda yer alan temel savunma seti hangisidir?

A) TLS ile HSTS, sertifika pinning ve VPN kullanımı
B) Çıktı kodlama, CSP ve HttpOnly çerez bayrağı
C) Parametreli sorgu, ORM kullanımı ve WAF kuralları
D) CDN, anycast yönlendirme ve hız sınırlama
E) Çevrimdışı 3-2-1 yedek, EDR, segmentasyon ve makro engelleme

22. Aralık 2021'de bir e-ticaret firmasının kullandığı Java günlükleme kütüphanesinde, uzaktan kod çalıştırmaya izin veren kritik bir açık duyuruluyor. BT ekibi hangi uygulamanın bu kütüphaneyi kullandığını bilmediği için etkiyi saatlerce çıkaramıyor. Bu deneyimden sonra ekibin öncelikle kurması gereken pratik hangisidir?

A) Tüm kullanıcı parolalarını argon2id ile yeniden hashlemek
B) Web sitesinin tamamını HTTP'den HTTPS'e taşımak
C) Veritabanı kullanıcısından DROP yetkisini kaldırmak
D) Yazılım bileşen envanteri (SBOM) tutmak ve hızlı yama disiplini kurmak
E) Çalışanlara yılda bir kez oltalama eğitimi vermek

23. Manisa'da bir diş kliniğinin randevu sisteminden hasta adları ve telefon numaralarının sızdığı fark ediliyor. Kliniğin BT danışmanı Pınar, sunumdaki hukuki çerçeveye göre hangi kanunun ve hangi yükümlülüğün devreye girdiğini açıklıyor. Pınar'ın açıklaması hangisi olmalıdır?

A) KVKK; ihlal ancak bir hasta şikâyet ederse bildirilir
B) 5651; trafik kayıtları derhâl silinerek iz kapatılmalıdır
C) KVKK; veri ihlali 72 saat içinde bildirilmelidir
D) TCK 245; kliniğin kart işlemleri hemen durdurulmalıdır
E) 5651; erişim engeli için sulh ceza hakimliğine gidilmelidir

24. Kula'da bir butik otel, misafirlerine ücretsiz Wi-Fi sunuyor. Otelin BT sorumlusu Barış'a, bu hizmet nedeniyle internet erişimine ilişkin kayıtların belirli bir süre saklanması gerektiği hatırlatılıyor. Sunumdaki “bilmen gereken üç kanun” özetine göre bu log saklama yükümlülüğü hangi düzenlemeden gelir?

A) 5651 sayılı İnternet Kanunu
B) KVKK'nın aydınlatma yükümlülüğü
C) VERBİS kayıt zorunluluğu
D) TCK 245 (kartların kötüye kullanılması)
E) TCK 243 (sisteme hukuka aykırı giriş)

25. Bilgisayar programcılığı öğrencisi Arda, alışveriş merkezindeki bir mağazanın kablosuz modem yönetim paneline varsayılan “admin/admin” bilgileriyle “sadece merak ettiği için” giriş yapıyor; hiçbir ayarı değiştirmeden çıkıyor. Sunumdaki hukuki çerçeveye göre bu davranış en doğrudan hangi düzenlemeyle ilgilidir?

A) TCK 244 — sistemi engelleme, bozma, veriyi yok etme
B) Ayar değişmediği ve zarar doğmadığı için suç oluşmaz
C) TCK 243 — bilişim sistemine hukuka aykırı giriş
D) TCK 245 — banka veya kredi kartının kötüye kullanılması
E) 5651 — internet ortamındaki yayınların düzenlenmesi

26. İşten çıkarılan bir sistem yöneticisi, ayrılmadan önce sunucuya bıraktığı zamanlanmış bir betikle firmanın sipariş veritabanını siliyor ve web sitesini çalışmaz hâle getiriyor. Bu eylem, sunumda özetlenen bilişim suçları maddelerinden en doğrudan hangisine karşılık gelir?

A) KVKK — veri sorumlusunun VERBİS kayıt zorunluluğu
B) TCK 244 — sistemi engelleme, bozma, verileri yok etme
C) 5651 — erişim sağlayıcıların log saklama yükümlülüğü
D) TCK 243 — sisteme hukuka aykırı olarak girme
E) TCK 245 — banka veya kredi kartını kötüye kullanma

27. Veri bilimi öğrencisi Yusuf, bir forumda paylaşılan ve bir e-ticaret sitesinden sızdırılmış müşteri veri setini bitirme projesinde “gerçek veri” olarak kullanmak istiyor. Sunumda bu konuda açık bir uyarı yer alıyor. Yusuf için en doğru davranış hangisidir?

A) Veriyi indirip firmaya bildirdikten sonra projede kullanmaya devam etmek
B) Veriyi indirip isim sütunlarını sildikten sonra projede kullanmak
C) Forum herkese açık olduğundan veriyi serbestçe projede kullanmak
D) Veriyi indirmemek; projede açık lisanslı ya da sentetik veri kullanmak
E) Veriyi indirip yalnızca kendi bilgisayarında şifreli olarak saklamak

28. Belediyenin halkla ilişkiler biriminde çalışan Seda, sunumdaki “kendi güvenliğin” görevlerini uyguluyor. E-posta hesabında ikinci faktör olarak hem SMS kodu hem de TOTP uygulaması seçeneği sunuluyor. Sunumdaki tavsiyeye göre Seda hangisini seçmeli ve neden?

A) SMS kodunu; telefon numarası değişmediği için en güvenlisidir
B) İkisini de kapatmalı; güçlü ve uzun bir parola tek başına yeterlidir
C) TOTP uygulamasını; SMS ikinci faktörde son tercih olmalıdır
D) SMS kodunu; TOTP uygulamaları internet olmadan hiç çalışmaz
E) TOTP uygulamasını; çünkü parolanın yerine geçip onu gereksizleştirir

29. Bir belediyenin dosya paylaşım sisteminde bulut depolama alanının (bucket) herkese açık bırakıldığı, yönetim panelinde ise üreticinin varsayılan parolasının hiç değiştirilmediği tespit ediliyor. OWASP Top 10 (2021) listesinde bu iki bulgu ortak olarak hangi kategoriye girer?

A) A06 Vulnerable Components
B) A04 Insecure Design
C) A02 Cryptographic Failures
D) A05 Security Misconfiguration
E) A09 Logging & Monitoring

2. HAFTA · Ağ Trafiği Analizi: Wireshark & Nmap

30. Kampüs ağında staj yapan Tolga, bir web isteğinin hangi katmanda hangi bilgiyi taşıdığını ekibine anlatıyor. Kaynak ve hedef port numaralarını, ayrıca bağlantının güvenilir mi yoksa hızlı mı kurulacağını belirleyen katmanı göstermek istiyor. TCP/IP modelinde bu katman hangisidir?

A) Ağ Erişimi katmanı (Ethernet)
B) Sunum katmanı (TLS)
C) Taşıma katmanı (TCP/UDP)
D) Uygulama katmanı (HTTP/DNS)
E) İnternet katmanı (IP)

31. Bir kargo firmasının şube ağında çalışan Melis, Wireshark'ta seçtiği bir paketin en alt katmanında kaynak ve hedef cihazların donanım adreslerini görüyor. Bu adresler sunumdaki TCP/IP modelinde hangi katmana aittir?

A) Ağ Erişimi katmanı — Ethernet/Wi-Fi ve MAC adresleri
B) Taşıma katmanı — port numaraları ve TCP bayrakları
C) Taşıma katmanı — UDP ile DNS sorguları
D) Uygulama katmanı — HTTP başlıkları ve çerezler
E) İnternet katmanı — IP adresleri, TTL ve yönlendirme bilgisi

32. Ağ dersinde hoca bir HTTP isteğini şöyle çiziyor: [Ethernet] [IP] [TCP :80] [HTTP: GET /index.html]. Öğrenci Cem, gönderim sırasında her katmanın veriye kendi başlığını eklemesine ne ad verildiğini soruyor. Doğru cevap hangisidir?

A) Şifreleme (encryption)
B) Parçalama (fragmentation)
C) Kapsülleme (encapsulation)
D) Sıkıştırma (compression)
E) Yönlendirme (routing)

33. Bir KOBİ'nin ağında sorun gideren Aslı, Wireshark'ta bir web sunucusuna yapılan bağlantının başlangıcını arıyor. Normal bir TCP bağlantısının kurulması sırasında görmesi gereken üç paketin doğru sırası hangisidir?

A) SYN → ACK → SYN-ACK
B) SYN → SYN-ACK → ACK
C) SYN → SYN-ACK → RST
D) ACK → SYN → SYN-ACK
E) SYN-ACK → SYN → ACK

34. Belediyenin BT biriminde çalışan Volkan, sunucuya bağlanamayan bir uygulamayı inceliyor. Wireshark'ta istemcinin aynı porta art arda SYN paketleri gönderdiğini, ancak sunucudan hiçbir yanıt (ne SYN-ACK ne RST) gelmediğini görüyor. Bu tablo en çok neye işaret eder?

A) Arada paketi sessizce düşüren bir güvenlik duvarı olabileceğine
B) Sunucunun o portu dinlemediğini RST paketiyle açıkça bildirdiğine
C) Bağlantının başarıyla kurulup veri aktarımına geçildiğine
D) Sunucunun SYN-ACK yerine doğrudan ACK gönderdiğine
E) İstemcinin DNS çözümlemesini hiç yapmadığına

35. Bir e-ticaret firmasının ağ yöneticisi Sibel, kendi sunucularını yazılı onaylı iç denetim kapsamında Nmap ile tarıyor. Raporda 25/tcp için “closed” yazıyor. Sunumdaki port durumu tablosuna göre bu sonuç neyi anlatır?

A) Port ulaşılabilir ama dinleyen servis yok; makine ayakta ve RST dönüyor
B) Makine kapalı olduğu için hiçbir porttan yanıt alınamıyor
C) Cevap gelmiyor; araya bir güvenlik duvarı giriyor demektir
D) Port açık mı kapalı mı belirsiz; tarama tekrarlanmalıdır
E) Bir servis dinliyor ve cevap veriyor; raporda ilk incelenecek yer burasıdır

36. Bir hastanenin bilgi işlem sorumlusu Emre, yetkili iç taramada şu sonucu görüyor: “3389/tcp filtered”. Yönetici, “Filtered demek port kapalı demek, konu kapandı” diyor. Emre'nin vermesi gereken en doğru cevap hangisidir?

A) Cevap alınamadı; araya güvenlik duvarı girdiği için durum belirsizdir
B) Port kesin olarak kapalıdır ve makinede bu servis hiç kurulu değildir
C) Makine kapalı olduğu için bu port hakkında bilgi edinmek mümkün değil
D) Port açıktır ve uzak masaüstü servisi şu anda dışarıya yanıt veriyor
E) Tarama hatalıdır; filtered yalnızca UDP taramasında görülebilen bir durumdur

37. Turgutlu'daki bir tekstil KOBİ'sinin sunucusunda yapılan yetkili taramada dört port “open” çıkıyor. BT sorumlusu Zeynep, sınırlı zamanı olduğu için hangi bulgudan başlaması gerektiğini düşünüyor. Sunuma göre “open” durumu savunmacı için ne ifade eder?

A) Tarama gürültülü olmuştur; sonuç tekrar alınmadan yorumlanmaz
B) Saldırı yüzeyi burasıdır; ilk incelenecek yer açık portlardır
C) Risk yoktur; port yalnızca makinenin ayakta olduğunu gösterir
D) Servis kapanmıştır; port yalnızca eski kayıtlarda görünmektedir
E) Güvenlik duvarı devrededir; portun durumu belirsiz kalmıştır

38. Kooperatifin sunucusunu yazılı izinle denetleyen Onur, aynı hedefe iki tarama yapıyor: biri el sıkışmayı tamamlamayan, diğeri tam bağlantı kuran türden. Sunucu loglarına bakan sistem yöneticisi, tam bağlantı kuran taramayı çok daha net görüyor. Bu taramada kullanılan Nmap seçeneği hangisidir?

A) -p- (tüm portların taranması)
B) -O (işletim sistemi tahmini)
C) -sT (tam TCP connect taraması)
D) -sS (SYN / yarı-açık tarama)
E) -sU (UDP taraması)

39. Bir belediyede ağ envanteri çıkaran Ceren, yalnızca TCP taraması yaptığı için DNS, SNMP ve DHCP gibi servisleri raporuna hiç yazamadığını fark ediyor. Kendi ağındaki bu eksikliği gidermek için sunumdaki hangi Nmap seçeneğini eklemelidir?

A) -sT
B) -sU
C) -sS
D) -A
E) -O

40. Bir kargo firmasının BT sorumlusu Furkan, kendi sunucularında yalnızca “hangi port açık” bilgisinin yetmediğini, yama önceliği için servislerin sürümlerini de görmesi gerektiğini düşünüyor. Sunumdaki tabloya göre hangi Nmap seçeneği bu amaçla kullanılır?

A) -O — işletim sistemi parmak izi tahmini
B) -sS — SYN ile yarı-açık port taraması
C) -sV — servis ve sürüm tespiti (banner okuma)
D) -sU — UDP portlarının taranması
E) -p- — tüm 65.535 TCP portunun taranması

41. Kampüs BT ekibinden Elif, varsayılan Nmap taramasında temiz görünen bir sunucuda, bir geliştiricinin test için 47001 numaralı portta unutulmuş bir yönetim paneli bıraktığını sonradan öğreniyor. Kendi taramalarında bu tür servisleri kaçırmamak için hangi seçeneği kullanmalıdır?

A) -sV ile ilk 1.000 portun sürümlerine bakmak
B) -sT ile yalnızca tam bağlantı kurmak
C) -O ile işletim sistemini tahmin etmek
D) -p- ile 65.535 TCP portunun tamamını taramak
E) -sU ile yalnızca UDP portlarını taramak

42. Bir bankanın şube ağında envanter güncelleyen Batuhan, IP adresi bilinen ama hangi işletim sistemini çalıştırdığı kayıtlarda yazmayan eski bir cihazla karşılaşıyor. Yetkili iç taramada cihazın Windows mu Linux mu olduğunu kestirmek için sunumdaki hangi seçenek uygundur?

A) -p-
B) -sU
C) -sS
D) -sT
E) -O

43. Bir hastanenin ağında yetkili tarama yapacak dış denetçi, -A seçeneğini kullanmayı öneriyor. Hastanenin bilgi işlem müdürü Gamze, bu seçeneğin neleri içerdiğini ve neden önceden IDS ekibine haber verilmesi gerektiğini soruyor. Doğru açıklama hangisidir?

A) Tüm portları tarar ama yanıtları kaydetmediği için logda görünmez
B) -sV, -O, betik ve traceroute'u birlikte çalıştırır; bu yüzden gürültülüdür
C) Yalnızca ilk 1.000 portu el sıkışma tamamlamadan tarar; bu yüzden iz bırakmaz
D) Yalnızca UDP portlarına bakar; TCP servislerini hiç incelemez
E) Yalnızca işletim sistemi tahmini yapar; servislerle ilgilenmez

44. Yetkili bir iç denetimde Akhisar'daki bir belediye sunucusu için şu satır raporlanıyor: “3306/tcp open mysql MySQL 5.5.60”. Veritabanı yalnızca aynı sunucudaki web uygulaması tarafından kullanılıyor. BT sorumlusu Uğur için en doğru iki yönlü önlem hangisidir?

A) MySQL'i olduğu gibi bırakıp yalnızca sunucuya antivirüs kurmak
B) MySQL'i güncel sürüme yükseltmek ve 3306'yı dış ağa kapatmak
C) 3306'yı başka bir port numarasına taşıyıp servisi gözden saklamak
D) Portu açık bırakıp -sV taramasını her ay yeniden çalıştırmak
E) Web uygulamasını kapatıp veritabanını internete açık tutmak

45. SOC stajyeri Dilek, ofis ağından bir saatlik trafik yakalamış ve yalnızca belirli bir istemciye ait paketleri incelemek istiyor; yakalamayı yeniden başlatmak istemiyor. Sunumdaki ayrıma göre hangi filtre türünü kullanmalıdır?

A) BPF filtresi — yalnızca yeni başlayan yakalamalara uygulanır
B) Güvenlik duvarı kuralı — istemcinin trafiğini ağda engeller
C) Capture filter — kayıtlı dosyadaki paketleri kalıcı olarak siler
D) Capture filter — yakalama başlamadan diske yazılacakları seçer
E) Display filter — yakalanmış trafiğin içinde daraltma yapar

46. Bir okulun ağında aralıklı yavaşlamayı inceleyen Sinan, Wireshark'ı gece boyunca açık bırakacak ve disk dolmasın diye yalnızca okul sunucusuna giden ya da gelen paketlerin kaydedilmesini istiyor. Bu ihtiyaç için sunumdaki hangi yaklaşım doğrudur?

A) Yakalama sırasında http display filter'ını açık tutmak
B) Yakalamayı filtresiz başlatıp sabah ip.addr display filter uygulamak
C) Yakalamayı durdurup Follow TCP Stream ile oturumları birleştirmek
D) Yakalama başlamadan host ile bir capture filter (BPF) tanımlamak
E) tcp.flags.syn==1 display filter'ı ile yalnızca SYN'leri görmek

47. Kampüs ağında çalışan Ebru, laboratuvar sunucusuna yapılan giriş isteklerini incelemek için yakalanmış HTTP trafiğinde yalnızca form gönderimlerini görmek istiyor. Sunumdaki örneklere göre hangi display filter bu amaca uygundur?

A) ip.addr == 192.168.1.1
B) http.request.method == "POST"
C) host 192.168.1.20
D) tcp.flags.syn == 1
E) tcp port 80

48. Ağ dersinde Kadir'e, Wireshark'ta bir bağlantının başlangıç paketlerini, yani el sıkışmayı hızlıca bulma görevi veriliyor. Sunumdaki örneğe göre bu amaçla kullanılacak display filter hangisidir?

A) tcp.stream eq 1
B) dns
C) ip.addr==192.168.1.20
D) tcp.flags.syn==1
E) http.request.method=="GET"

49. Bir kooperatifin iç portalında sorun gideren Merve, yetkili olarak kendi ofis bilgisayarında Wireshark yakalaması alıyor ve giriş isteği için Follow TCP Stream açıyor. Akışta “POST /login HTTP/1.1” satırının altında kullanıcı adı ve parolayı açıkça okuyabiliyor. Merve'nin bu bulgu için önereceği temel düzeltme hangisidir?

A) Giriş formunu GET yöntemine çevirip parolayı adreste taşımak
B) Kullanıcılara daha uzun ve karmaşık parolalar seçtirmek
C) Portalı HTTPS'e (TLS) taşıyıp HTTP girişini kapatmak
D) Wireshark kurulumunu ofis bilgisayarından kaldırmak
E) Portalı 80 yerine 8080 portunda yayınlamaya başlamak

50. Aynı HTTP giriş akışında Taner, sunucunun “HTTP/1.1 302 Found” yanıtıyla birlikte “Set-Cookie: session=8f2a…” başlığı döndürdüğünü görüyor. Parola dışında bu satırın açık metin görünmesi neden ayrıca bir güvenlik bulgusudur?

A) Çerez görünür olduğunda TCP el sıkışması yeniden başlatılır
B) Çerez yalnızca sayfa rengini tuttuğu için bir risk oluşturmaz
C) 302 yanıtı sunucunun çöktüğünü ve giriş hizmetinin tamamen kesildiğini gösterir
D) Set-Cookie başlığı istemcinin MAC adresini dışarıya sızdırır
E) Çerezi okuyan biri, kullanıcının açık oturumunu onun yerine sürdürebilir

51. Bir belediyenin eski dosya sunucusunu inceleyen Özge, yetkili yakalamada 21 numaralı porttaki oturumda USER ve PASS komutlarını açık metin olarak görüyor. Sunumdaki “şifresiz olanı şifreli kardeşiyle değiştir” tablosuna göre hangi geçiş önerilmelidir?

A) FTP yerine SFTP ya da FTPS kullanmak
B) FTP yerine HTTP ile dosya yüklemek
C) FTP'yi 21 yerine 2121 portuna taşımak
D) FTP'yi yalnızca UDP üzerinden çalıştırmak
E) FTP yerine Telnet ile dosya aktarmak

52. Bir kargo deposundaki ağ anahtarlarını yöneten Engin, cihazlara hâlâ Telnet ile bağlandığını, bunun her tuş vuruşunun pakette okunabilmesi demek olduğunu öğreniyor. Yönetim erişimi için sunumda önerilen şifreli karşılık hangisidir?

A) DNS (53)
B) SNMP (161)
C) SSH (22)
D) HTTP (80)
E) FTP (21)

53. Bir bankanın şube BT sorumlusu Tuğba, sunumdaki protokol tablosunu kendi ağ politikasına aktarıyor. Aşağıdaki şifresiz–şifreli eşleştirmelerinden hangisi sunumdaki tabloya göre doğru bir eşleştirme DEĞİLDİR?

A) DNS :53 (UDP) yerine DoH / DoT
B) FTP :21 yerine SFTP / FTPS
C) HTTP :80 yerine HTTPS :443 (TLS)
D) Telnet :23 yerine SSH :22
E) HTTP :80 yerine Telnet :23

54. Kampüs ağında gizlilik farkındalığı semineri hazırlayan Yasin, HTTPS kullanılsa bile klasik DNS sorgularının Wireshark'ta okunabildiğini gösteriyor: hangi istemcinin hangi alan adını sorduğu açıkça görünüyor. Bu bilgi sızıntısını azaltmak için sunumda hangi teknoloji önerilir?

A) DNS'i 53 yerine 5353'e taşımak
B) UDP yerine TCP ile DNS
C) DoH / DoT (şifreli DNS)
D) Capture filter tanımlamak
E) Telnet üzerinden DNS

55. Bir KOBİ'de staj yapan Nihan, ofisteki anahtarlamalı (switch) ağa bağlı dizüstü bilgisayarında, kendi işvereninin izniyle Wireshark çalıştırıyor. Diğer çalışanların web trafiğini göremeyip yalnızca kendi bilgisayarının paketlerini gördüğünü fark ediyor. Bunun nedeni nedir?

A) Wireshark varsayılan ayarda yalnızca UDP paketlerini yakaladığı için TCP trafiği görünmez
B) Switch ağında yalnızca DNS paketleri yakalanabilir, web trafiği yakalanmaz
C) Diğer çalışanların trafiği HTTPS olduğu için paket olarak hiç iletilmez
D) Display filter açık olmadığında Wireshark hiçbir paketi göstermez
E) Switch, paketleri yalnızca hedef porta iletir; normalde başkasının trafiği gelmez

56. Bir e-ticaret firmasının SOC ekibinde çalışan Alper, Suricata'dan bir alarm alıyor: dış bir IP adresi 20 saniye içinde aynı sunucunun yüzlerce farklı portuna SYN paketi göndermiş, çoğu bağlantı tamamlanmamış. Bu alarm en çok hangi etkinliğe işaret eder ve ilk adım ne olmalıdır?

A) Normal web trafiği; kampanya günü çok kullanıcı aynı anda bağlandığı için yok saymak
B) Yazılım güncellemesi; sunucu yama indirdiği için alarmı kapatmak
C) Yedekleme işi; büyük dosya aktarımı başladığı için bekleyip izlemek
D) DNS çözümlemesi; istemcinin alan adı sorguladığını not edip kapatmak
E) Port taraması; kaynağı ve hedefi kayda alıp tarama yetkili mi diye kontrol etmek

57. Bilgisayar programcılığı öğrencisi Büşra, Nmap'i öğrendikten sonra oturduğu sitenin yönetim ofisine ait ağı ve komşu kafenin Wi-Fi'ına bağlı cihazları “sadece öğrenmek için” taramayı düşünüyor. Sunumdaki uyarıya göre en doğru değerlendirme hangisidir?

A) Sahibinin izni olmadan başkasının ağını taramak TCK 243–245 kapsamında suç oluşturabilir
B) Tarama yalnızca -sS ile yapılırsa iz kalmadığı için suç sayılmaz
C) Kafenin Wi-Fi'ı herkese açık ve parolasız olduğu için ağa bağlı tüm cihazları taramak serbesttir
D) Yalnızca port taranıp sisteme girilmediği için hiçbir hukuki sonuç doğmaz
E) Amaç eğitim olduğunda yazılı izin gerekmez, sözlü bilgi vermek yeterlidir

58. Bir bilişim firması, Salihli'deki bir hastanenin dış IP aralığında sızma testi yapmak üzere anlaşıyor. Yazılı sözleşmede yalnızca web sunucusu ile e-posta sunucusu kapsamda; test sırasında ekipten Erdem aynı aralıkta hastanenin laboratuvar cihazlarına ait bir IP daha fark ediyor. Erdem'in yapması gereken hangisidir?

A) IP'yi taramak ama sonuçları rapora yazmadan kendinde tutmak
B) Testi tamamen bırakıp hastaneye hiçbir bilgi vermeden ayrılmak
C) Sözleşmedeki IP aralığıyla aynı blokta olduğu için IP'yi de kapsamda sayıp taramak
D) IP'yi yalnızca -sS ile taramak, çünkü bu tarama iz bırakmaz
E) Bu IP'yi taramadan durumu bildirmek ve kapsam için yazılı onay istemek

3. HAFTA · Kriptografi 101

59. Bir e-ticaret firmasında yeni işe başlayan geliştirici Cenk, ödeme servisinin API anahtarını yapılandırma dosyasına Base64'e çevirerek yazıyor ve kod incelemesinde “anahtarı şifreledim” diyor. Ekip lideri Hande bu ifadeye itiraz ediyor. Hande'nin gerekçesi hangisidir?

A) Base64 bir kodlamadır; anahtarsız geri çevrilir ve gizlilik sağlamaz
B) Base64 asimetrik şifrelemedir; açık anahtarı da dosyaya yazmak gerekir
C) Base64 dijital imzadır; yalnızca anahtarın kimden geldiğini kanıtlar
D) Base64 bir hash'tir; geri çevrilemediği için anahtar bir daha okunamaz
E) Base64 simetrik şifrelemedir ama anahtar boyutu artık yetersiz kalmıştır

60. Bir kooperatifin muhasebecisi Sevgi, yıllık arşivi harici diske koymadan önce şifreliyor. Aynı parolayı ve aynı anahtarı kullanarak dosyayı daha sonra yine kendisi açacak. Sunumdaki sınıflandırmaya göre bu kullanım hangi şifreleme türüne girer?

A) Kriptografik hash
B) Asimetrik şifreleme
C) Dijital imza
D) Base64 kodlama
E) Simetrik şifreleme

61. Bir hastanenin laboratuvar birimi, sonuç dosyalarını dış bir referans laboratuvarına gönderiyor. BT sorumlusu Oğuz, karşı laboratuvarın kendisine yalnızca açık (public) anahtarını göndermesini istiyor. Oğuz bu anahtarla ne yapmalıdır ve şifreli dosyayı kim açabilir?

A) Dosyayı karşı tarafın açık anahtarıyla şifreler; o anahtara sahip herkes dosyayı açabilir
B) Dosyayı kendi açık anahtarıyla şifreler; karşı taraf aynı açık anahtarla açar
C) Dosyayı açık anahtarla hash'ler; karşı taraf özetten dosyayı geri hesaplar
D) Dosyayı karşı tarafın açık anahtarıyla şifreler; yalnızca onun gizli anahtarı açar
E) Dosyayı karşı tarafın açık anahtarıyla imzalar; imza dosyayı gizli tutar

62. Bir kargo firmasının iki şubesi arasında her gece 300 GB'lık arşiv aktarılıyor. Stajyer Hülya, “Madem RSA anahtar dağıtım sorununu çözüyor, tüm arşivi doğrudan RSA ile şifreleyelim” öneriyor. Sunuma göre bu önerinin temel sorunu nedir?

A) RSA yalnızca hash üretir; veriyi şifreleme yeteneği bulunmamaktadır
B) Asimetrik şifreleme yavaştır; büyük veriyi doğrudan şifrelemek için kullanılmaz
C) RSA anahtarları Base64 olduğu için şifreleme herkesçe geri çevrilebilir
D) Asimetrik şifreleme gizlilik sağlamaz; yalnızca verinin bütünlüğünü korur
E) RSA ile şifrelenen veri yalnızca aynı şubede açılabilir, karşı şubede hiçbir şekilde açılamaz

63. Kampüs ağ dersinde Ferhat'a, bir HTTPS bağlantısında asimetrik ve simetrik kriptografinin nasıl birlikte çalıştığını tek cümleyle özetlemesi söyleniyor. Sunumdaki “TLS'in özü” ifadesine en uygun özet hangisidir?

A) Tüm trafik baştan sona yalnızca RSA ile şifrelenir, AES kullanılmaz
B) Hızlı simetrik kripto anahtarı taşır, yavaş asimetrik kripto veriyi taşır
C) Sunucu ve istemci her pakette yeni bir RSA anahtar çifti üretir
D) Tüm trafik yalnızca SHA-256 ile özetlenir; şifreleme hiç yapılmaz
E) Yavaş asimetrik kripto anahtarı taşır, hızlı simetrik kripto veriyi taşır

64. Bir bankanın şube sistemlerini inceleyen İlker, TLS el sıkışmasının ikinci adımını anlatıyor: istemci, rastgele ürettiği oturum anahtarını sunucunun açık anahtarıyla şifreleyip göndermiştir. Sunucu bu oturum anahtarını nasıl elde eder?

A) Oturum anahtarının SHA-256 özetini alarak
B) Kendi gizli (private) anahtarıyla şifreyi çözerek
C) İstemcinin gizli anahtarını isteyerek
D) Sertifika otoritesinden oturum anahtarını indirerek
E) Kendi açık anahtarıyla şifreyi çözerek

65. Bir belediyenin eski e-belge sisteminde yapılan denetimde, arşiv dosyalarının 3DES ile, bazı eski bağlantıların da RC4 ile şifrelendiği raporlanıyor. Denetçi Ayten, sunumdaki 2026 varsayılanlarına göre simetrik şifreleme için hangi geçişi önermelidir?

A) RSA-1024 ile tüm arşivi şifrelemek
B) AES-256-GCM ya da ChaCha20'ye geçmek
C) Dosyaları MD5 ile özetleyip saklamak
D) DES'e geçip anahtar sayısını artırmak
E) Dosyaları Base64 ile kodlayıp saklamak

66. Bir kargo firmasının yazılım ekibinden Doğan, AES-256-GCM'i seçtikten sonra ayrıca bir bütünlük kontrolü eklemeleri gerekip gerekmediğini soruyor. Sunumdaki tablo notuna göre GCM modunun öne çıkan özelliği nedir?

A) Asimetrik olduğu için açık ve gizli anahtar çifti kullanır
B) Veriyi geri döndürülemez biçimde özetler
C) Yalnızca parola depolama için tasarlanmıştır
D) Anahtar dağıtım sorununu tek başına çözer
E) Şifrelemeyle aynı anda bütünlük de sağlar (AEAD)

67. Bir kamu kurumunun sunucusunda yapılan incelemede Esra, VPN cihazının hâlâ RSA-1024 anahtar kullandığını görüyor. Sunumdaki öneriler tablosuna göre asimetrik şifreleme için uygun yenileme hangisidir?

A) RSA-3072+ ya da ECC (Ed25519)
B) RSA-512 ya da RSA-768
C) MD5 ya da SHA-1
D) Base64 ya da Hex
E) 3DES ya da RC4

68. Bir IoT sayaç projesinde çalışan Koray, işlemci gücü ve belleği kısıtlı cihazlarda anahtar çiftine dayalı imza kullanmak istiyor. Sunumdaki nota göre ECC'yi (ör. Ed25519) bu tür cihazlarda cazip kılan özellik hangisidir?

A) Geri döndürülemez bir hash fonksiyonu olması
B) Küçük anahtarla yüksek güvenlik vermesi
C) Anahtar gerektirmeden şifreleme yapabilmesi
D) Base64 ile uyumlu çıktı üreten tek yöntem olması
E) Simetrik olduğu için tek anahtar kullanması

69. Bir KOBİ'nin yöneticisi Nurcan, “Eski sistemimizde DES ile şifreleme var; şifresizden iyidir, dokunmayalım” diyor. BT danışmanı Selim, sunumdaki uyarıya dayanarak itiraz ediyor. Selim'in en güçlü gerekçesi hangisidir?

A) DES aslında bir hash algoritmasıdır ve veriyi hiç şifrelemez
B) Eski algoritma sahte güven verdiği için şifrelememekten daha tehlikeli olabilir
C) DES ile şifrelenen veri yalnızca Base64 ile okunabilir hâle gelir
D) DES yalnızca asimetrik anahtarlarla çalıştığı için yavaştır
E) Şifreleme yasal olarak yalnızca kamu kurumlarında zorunlu olduğu için KOBİ'yi ilgilendirmez

70. Bir yazılım firmasında Gül, müşterilerin indirdiği kurulum dosyalarının yanında yayımlanan özetlerin hâlâ MD5 ile üretildiğini fark ediyor. Sunuma göre MD5 ve SHA-1'den neden kaçınılmalı ve yerine ne kullanılmalıdır?

A) Çok yavaş oldukları için; yerine Base64 ile kodlanmış özet
B) Geri döndürülebildikleri için; yerine AES-256
C) Anahtar gerektirdikleri için; yerine RC4 kullanımı
D) Çakışma üretilebildiği için; yerine SHA-256 ya da SHA-3
E) Asimetrik oldukları için; yerine 3DES şifrelemesi

71. Bir bankanın iç denetiminde Rıza'ya, veritabanında saklanan bir SHA-256 özetinden orijinal girdinin doğrudan hesaplanıp hesaplanamayacağı soruluyor. Sunumdaki dört özellikten hangisi bu sorunun cevabını verir?

A) Çığ etkisi
B) Çakışma direnci
C) Simetrik anahtar kullanımı
D) Tek yönlülük (preimage direnci)
E) Deterministik olma

72. Bir belediyenin yedekleme ekibinden Bahar, aynı yedek dosyasının özetini pazartesi ve cuma günleri ayrı ayrı hesaplıyor ve iki sonucun birebir aynı çıktığını görüyor. Bu sonuç hash fonksiyonunun hangi özelliğinin doğal bir gereğidir?

A) Deterministik olma
B) Çığ etkisi
C) Tek yönlülük
D) Çakışma direnci
E) Tuzlama (salt)

73. OpenSSL laboratuvarında Taylan, belge.txt'nin SHA-256 özetini alıyor, sonra dosyadaki tek bir harfi büyük harfe çevirip özeti yeniden hesaplıyor. İki özetin baştan sona tamamen farklı olduğunu görüyor. Gözlemlediği özellik hangisidir ve güvenlikteki önemi nedir?

A) Çığ etkisi; en ufak değişiklik bile özet karşılaştırmasında ortaya çıkar
B) Çakışma; iki farklı dosya aynı özeti vermiş ve hash kırılmıştır
C) Tek yönlülük; değişen harf özetten geri hesaplanıp bulunabilir
D) Tuzlama; OpenSSL her hesaplamada özete otomatik olarak rastgele bir değer ekler
E) Deterministik olma; aynı dosya her seferinde farklı özet üretir

74. Bir hastanede kimlik doğrulama sistemini inceleyen Şule, eski bir modülde kullanıcı parolalarının AES ile şifrelenip anahtarın aynı sunucudaki yapılandırma dosyasında tutulduğunu görüyor. Sunuma göre bu yaklaşımın temel sorunu nedir?

A) AES yalnızca asimetrik anahtarla çalıştığı için bu kullanım teknik olarak mümkün değil
B) AES çok yavaş olduğu için girişler gecikir; daha hızlı bir algoritma seçilmeli
C) AES bir hash olduğu için parolalar geri çözülemez ve kullanıcı giriş yapamaz
D) Anahtar sızarsa tüm parolalar geri çözülür; parola şifrelenmez, hash'lenir
E) Parolalar AES ile şifrelendiğinde uzunlukları değiştiği için doğrulama bozulur

75. Bir e-ticaret sitesinin veritabanı sızıyor; parolaların tuzsuz SHA-256 ile saklandığı anlaşılıyor. Güvenlik danışmanı Murat yönetime, saldırganın bu özetlerden kısa sürede çok sayıda parolayı bulabileceğini söylüyor. Murat'ın bu değerlendirmesinin sunumdaki gerekçesi hangisidir?

A) SHA-256 geri döndürülebilir bir şifreleme olduğu için anahtarla çözülebilir
B) SHA-256 deterministik olmadığı için her parola birden çok özet üretir
C) Düz SHA-256 çok hızlıdır; tuz olmadan GPU ile saniyede milyarlarca deneme yapılır
D) SHA-256 asimetrik olduğu için açık anahtarı bilen herkes parolayı doğrudan görebilir
E) SHA-256 çığ etkisine sahip olmadığı için benzer parolalar aynı özeti verir

76. Bir kampüs uygulamasının veritabanında Canan, iki farklı öğrencinin aynı parolayı seçtiğini biliyor; ancak tablodaki iki parola özeti birbirinden tamamen farklı görünüyor. Bunu sağlayan ve önceden hesaplanmış özet tablolarını (rainbow table) işe yaramaz kılan uygulama hangisidir?

A) Parolaların Base64 ile kodlanması
B) Parolaların AES ile şifrelenmesi
C) Parolaların büyük harfe çevrilmesi
D) Her parolaya benzersiz bir salt (tuz) eklenmesi
E) Özetin MD5 ile yeniden özetlenmesi

77. Bir bankanın yazılım ekibinde Halil, bcrypt maliyet parametresini artırmayı öneriyor; bir ekip arkadaşı “Girişleri yavaşlatmak kötü bir şey değil mi?” diye soruyor. Sunumdaki parola depolama yaklaşımına göre Halil'in cevabı hangisi olmalıdır?

A) Yavaş hash yalnızca dosya bütünlüğünü kontrol etmek için seçilir
B) Yavaşlık burada bir özelliktir; kaba kuvvet denemelerini pahalı hâle getirir
C) Maliyet arttıkça parola özetten geri çözülebilir hâle gelir
D) Yavaşlık yalnızca sunucuyu aşırı yükten korur; parolaların güvenliğine bir katkısı yoktur
E) Maliyet parametresi yalnızca salt'ın uzunluğunu belirler

78. Bir belediye uygulamasının veritabanında Sena, parola sütununda şöyle bir değer görüyor: $2b$12$Kx7… Ayrı bir salt sütunu bulunmuyor. Sunumdaki örneğe göre bu kayıtla ilgili en doğru yorum hangisidir?

A) MD5 özeti; 12 parola uzunluğudur ve salt ayrıca tutulmalıdır
B) RSA imzası; 12 anahtar boyutudur ve açık anahtarla doğrulanır
C) bcrypt özeti; salt değerin içine gömülüdür ve 12 maliyet parametresidir
D) AES şifreli parola; 12 anahtar uzunluğunu gösterir ve salt yoktur
E) Base64 kodlu parola; 12 karakterlik kısmı çözülünce parola okunur

79. Manisa'daki bir hukuk bürosunda çalışan Orhan, müvekkillere gönderdiği sözleşmelerin kendisinden geldiğini ve yolda değiştirilmediğini kanıtlamak istiyor. Sunumdaki dijital imza akışına göre Orhan hangi anahtarla imzalamalı, alıcılar hangi anahtarla doğrulamalıdır?

A) Orhan ve alıcılar aynı simetrik anahtarı kullanarak imzalar ve doğrular
B) Orhan kendi açık anahtarıyla imzalar; alıcılar Orhan'ın gizli anahtarıyla doğrular
C) Orhan kendi gizli anahtarıyla imzalar; alıcılar Orhan'ın açık anahtarıyla doğrular
D) Orhan belgeyi Base64'e çevirir; alıcılar çözülen metni okuyarak doğrular
E) Orhan alıcının açık anahtarıyla imzalar; alıcılar kendi gizli anahtarıyla doğrular

80. Bir kooperatif, üyelerine gönderdiği genel kurul duyurusunu dijital olarak imzalıyor. Üyelerden Damla, “İmzalı olduğuna göre bu duyuruyu başkaları okuyamaz, değil mi?” diye soruyor. Sunuma göre dijital imza tek başına hangi güvenceleri sağlar?

A) Gizlilik ve bütünlük; kimliği doğrulamaz
B) Bütünlük ve kimlik doğrulama; gizlilik sağlamaz
C) Yalnızca erişilebilirlik; belgeyi yedekler
D) Yalnızca gizlilik; belgeyi herkesten saklar
E) Gizlilik ve erişilebilirlik; bütünlük sağlamaz

81. OpenSSL laboratuvarında Kübra, belge.txt'yi özel anahtarıyla imzalayıp “Verified OK” sonucunu alıyor. Ardından dosyaya tek bir boşluk ekleyip aynı doğrulama komutunu çalıştırıyor ve doğrulama başarısız oluyor. Bu sonucun doğru yorumu hangisidir?

A) Açık anahtar boşluk karakterini tanımadığı için doğrulama hata vermiştir
B) İmza dosyası her doğrulamadan sonra otomatik olarak geçersiz hâle gelir
C) Özel anahtar bozulmuştur; anahtar çiftinin yeniden üretilmesi gerekir
D) Belgenin yeniden hesaplanan özeti, imzadaki özetle artık eşleşmemektedir
E) OpenSSL aynı belgeyi ikinci kez doğrulamaya izin vermemektedir

82. Bir e-ticaret sitesinin müşterisi Ufuk, tarayıcının adres çubuğundaki kilit simgesine tıklayıp sitenin TLS sertifikasını inceliyor. Sunumdaki “Bağlantı” notuna göre bir TLS sertifikası temelde nedir?

A) Sunucunun gizli anahtarının, her ziyarette tarayıcıya güvenle gönderilen şifreli bir kopyası
B) Sunucunun açık anahtarının, güvenilir bir CA tarafından dijital imzalanmış hâli
C) Sunucu ile tarayıcının paylaştığı ve her oturumda değişen bir AES anahtarı
D) Kullanıcının parolasının bcrypt ile özetlenip sunucuda saklandığı bir kayıt
E) Sitenin tüm sayfalarının SHA-256 özetlerini içeren ve CA'nın tuttuğu bir liste

83. Bir kargo firmasında Meltem, bir geliştiricinin sunucu TLS sertifikasına ait ozel.pem dosyasını yanlışlıkla herkese açık bir Git deposuna gönderdiğini fark ediyor. Dosya iki saat sonra depodan siliniyor. Sunumdaki anahtar hijyeni ilkesine göre en doğru adım hangisidir?

A) Aynı özel anahtardan yeni bir açık anahtar türetip yalnızca onu değiştirmek
B) Anahtar dosyasını Base64'e çevirip depoya yeniden yüklemek
C) Anahtarı ele geçirilmiş saymak; sertifikayı iptal edip yeni anahtar çifti üretmek
D) Dosya silindiği için anahtarı kullanmaya devam etmek ve olayı kapatmak
E) Depoyu gizli yapıp anahtarın başka bir yerde kullanılmadığını varsaymak

84. Laboratuvar raporunu hazırlayan Tarık, şu komutu çalıştırıp “Verified OK” çıktısını alıyor: openssl dgst -sha256 -verify acik.pem -signature belge.sig belge.txt. Bu komut ne yapmaktadır?

A) acik.pem dosyasından yeni bir gizli anahtar türetip kaydeder
B) belge.txt'nin özetini gizli anahtarla imzalayıp belge.sig üretir
C) belge.txt'yi AES-256 ile çözüp sonucu ekrana yazdırır
D) belge.sig imzasını açık anahtarla doğrulayıp belgeyle eşleştirir
E) belge.txt'yi açık anahtarla şifreleyip belge.sig dosyasına yazar

85. OpenSSL laboratuvarında Yeliz, şu komutu çalıştırıyor ve kendisinden bir parola isteniyor: openssl enc -aes-256-cbc -pbkdf2 -in belge.txt -out belge.enc. Bu adım sunumdaki üç kriptografik araçtan hangisine örnektir?

A) Simetrik şifreleme
B) Asimetrik şifreleme
C) Kriptografik hash
D) Dijital imza
E) Base64 kodlama

86. Laboratuvarda Hasan, önce “openssl genpkey -algorithm RSA -pkeyopt rsa_keygen_bits:3072 -out ozel.pem” ile anahtar üretiyor, ardından “openssl rsa -in ozel.pem -pubout -out acik.pem” komutunu çalıştırıyor. İkinci komutun amacı nedir?

A) Açık anahtardan, gizlenecek ikinci bir özel anahtar üretmek
B) ozel.pem dosyasının SHA-256 özetini hesaplayıp yazmak
C) Anahtar çiftini CA'ya gönderip sertifika imzalatmak
D) Gizli anahtardan, paylaşılabilecek açık anahtarı çıkarmak
E) ozel.pem dosyasını AES ile şifreleyip korumaya almak

87. Kriptografi tekrarında Leyla, bir arkadaşının hazırladığı “iyi bir kriptografik hash fonksiyonunun özellikleri” listesini kontrol ediyor. Aşağıdakilerden hangisi sunumdaki dört özellikten biri DEĞİLDİR?

A) Özetten girdinin geri hesaplanamaması
B) Girdideki tek bit değişince özetin tamamen değişmesi
C) Doğru anahtarla özetten girdinin geri çözülebilmesi
D) Aynı girdinin her zaman aynı özeti vermesi
E) Aynı özeti veren iki girdinin pratikte bulunamaması

4. HAFTA · OWASP Top 10 — Bölüm 1

88. Bir e-ticaret firmasının güvenlik ekibinde Cansu, eski bir eğitim notunda XSS'in OWASP Top 10 listesinde ayrı bir sıra olarak geçtiğini görüyor. Sunumdaki OWASP Top 10 (2021) sürümüne göre XSS bugün hangi kategorinin altında ele alınır?

A) A03 Injection
B) A01 Broken Access Control
C) A05 Security Misconfiguration
D) A07 Auth & Session Failures
E) A10 Server-Side Request Forgery

89. Bir kargo firmasının müşteri portalında, kullanıcıların adres çubuğundaki gönderi numarasını değiştirerek başka müşterilerin gönderi bilgilerini görebildiği ortaya çıkıyor. Denetçi Ozan bu bulguyu OWASP Top 10 (2021) listesinde hangi kategoriye yazmalıdır?

A) A09 Logging & Monitoring
B) A03 Injection
C) A02 Cryptographic Failures
D) A06 Vulnerable Components
E) A01 Broken Access Control

90. Belediyenin eski abone sisteminde yapılan denetimde Aylin, kullanıcı parolalarının veritabanında açık metin tutulduğunu ve sunucunun yalnızca eski TLS sürümlerini desteklediğini tespit ediyor. Bu iki bulgu OWASP Top 10 (2021) listesinde ortak olarak hangi kategoriye girer?

A) A05 Security Misconfiguration
B) A01 Broken Access Control
C) A02 Cryptographic Failures
D) A04 Insecure Design
E) A08 Software & Data Integrity

91. Bir kampüs uygulamasının bağımlılık taramasında Berk, aylardır güncellenmeyen ve bilinen kritik açığı olan bir günlükleme kütüphanesi buluyor. Kod kendi içinde hatasız görünse de bu bulgu OWASP Top 10 (2021) listesinde hangi kategoriye aittir?

A) A04 Insecure Design
B) A09 Logging & Monitoring
C) A03 Injection
D) A06 Vulnerable Components
E) A07 Auth & Session Failures

92. Bir hastane portalına yapılan saldırının ardından Seren, saldırganın üç hafta boyunca sistemde dolaştığını, ancak başarısız giriş denemeleri ve yetkisiz erişimler için hiçbir kayıt ya da alarm bulunmadığını raporluyor. Bu eksiklik hangi OWASP Top 10 (2021) kategorisine karşılık gelir?

A) A09 Logging & Monitoring
B) A02 Cryptographic Failures
C) A10 Server-Side Request Forgery
D) A08 Software & Data Integrity
E) A05 Security Misconfiguration

93. Bir e-ticaret sitesinin “bağlantıdan ürün görseli getir” özelliğinde, sunucunun kullanıcı tarafından verilen adrese istek attığı görülüyor. Test eden Fatih, bu özellikle sunucunun dışarıdan erişilemeyen iç yönetim adreslerine de istek gönderebildiğini fark ediyor. Bu açık hangi kategoriye girer?

A) A03 Injection
B) A04 Insecure Design
C) A01 Broken Access Control
D) A10 Server-Side Request Forgery
E) A07 Auth & Session Failures

94. Bir kooperatifin üye uygulamasında, geliştirme başlamadan hiçbir tehdit modelleme yapılmadığı; örneğin parola sıfırlama akışının baştan herkesin tahmin edebileceği bilgilere dayalı tasarlandığı ortaya çıkıyor. Kodlama hatası yok ama akış doğası gereği güvensiz. Bu durum hangi kategoriye girer?

A) A05 Security Misconfiguration
B) A03 Injection
C) A09 Logging & Monitoring
D) A04 Insecure Design
E) A06 Vulnerable Components

95. Bir bankanın internet şubesi yöneticisi Neslihan, “Sitemiz baştan sona HTTPS, bu yüzden SQL injection bizi etkilemez” diyor. Güvenlik uzmanı Ahmet sunumdaki köprü slaytına dayanarak itiraz ediyor. Ahmet'in gerekçesi hangisidir?

A) HTTPS yalnızca yolda korur; şifreli kanaldan gelen kötü girdiyi engellemez
B) HTTPS kullanan sitelerde injection yalnızca saldırgan aynı ağdaysa mümkündür
C) HTTPS veritabanı bağlantısını da şifrelediği için SQL injection zaten imkânsız hâle gelir
D) HTTPS sertifikası olan sitelere tarayıcılar kötü girdi gönderilmesine izin vermez
E) HTTPS yalnızca statik sayfaları şifreler; form verileri her zaman açık metin olarak gider

96. Bir yazılım dersinde Hilal'e, SQL injection'ın kök nedenini tek cümleyle açıklaması söyleniyor. Sunumdaki “temel mantık” slaytına göre en doğru açıklama hangisidir?

A) Tarayıcının oturum çerezini her isteğe otomatik olarak eklemesi
B) Veritabanı sunucusunun internete açık bir portta dinlemesi ve uygulamaya şifresiz bağlanması
C) Web sunucusunun eski bir TLS sürümü kullanması ve trafiğin dinlenebilmesi
D) Kullanıcı parolalarının veritabanında tuzsuz SHA-256 ile özetlenerek saklanması
E) Uygulamanın veri sandığı kullanıcı metnini, veritabanının komut olarak çalıştırması

97. Bir belediye portalının giriş loglarını inceleyen SOC stajyeri Can, bazı denemelerde kullanıcı adı alanına tırnak işareti ve mantıksal ifadeler içeren garip girdiler yazıldığını, ardından parola doğru olmadığı hâlde girişin başarılı sayıldığını görüyor. Bu bulgu en çok hangi kod kusuruna işaret eder?

A) Sunucunun yalnızca HTTP üzerinden yayın yapması
B) Parola değiştirme formunda anti-CSRF token bulunmaması
C) Kullanıcı girdisinin SQL sorgusuna doğrudan metin olarak birleştirilmesi
D) Oturum çerezinde HttpOnly bayrağının kullanılmamış olması
E) Sayfadaki kullanıcı yorumlarının HTML çıktısına kaçırılmadan olduğu gibi basılması

98. Bir KOBİ'nin web uygulamasında kod incelemesi yapan Duygu, giriş sorgusunun kullanıcı adı ve parola özetinin doğrudan SQL metnine eklenmesiyle oluşturulduğunu görüyor. Sunuma göre bu kusur için birincil düzeltme hangisidir?

A) Hata mesajlarını kullanıcıya göstermeyip yalnızca loglamak
B) Sitenin önüne bir WAF koyup bilinen kalıpları filtrelemek
C) Sorguyu parametreli sorgu (prepared statement) ile yeniden yazmak
D) Kullanıcı adındaki tırnak ve tire işaretlerini bir kara listeyle tek tek silmek
E) Giriş sayfasını HTTPS'e taşıyıp HSTS başlığını açmak

99. Yazılım stajyeri Mehmet, parametreli sorguya geçtikten sonra kullanıcı adı alanına yazılan özel karakterlerin neden artık sorgunun mantığını değiştiremediğini merak ediyor. Sunumdaki düzeltme notuna göre bunun nedeni nedir?

A) Parametreli sorgu girdiyi Base64'e çevirdiği için karakterler etkisizleşir
B) Girdi artık yalnızca veri olarak bağlanır, asla kod olarak çalıştırılmaz
C) Parametreli sorgu girdiyi AES ile şifreleyip veritabanına öyle gönderir
D) Veritabanı parametreli sorgularda yalnızca rakam kabul eden kipe geçer
E) Parametreli sorgu tüm özel karakterleri otomatik olarak silip kısaltır

100. Bir kargo firmasının takip sayfasında gönderi ID'si her zaman yalnızca rakamlardan oluşuyor. Geliştirici Yağmur, parametreli sorguya ek olarak bu alana yalnızca rakam kabul eden bir kontrol koyuyor. Sunumdaki savunma tablosuna göre bu kontrol nasıl sınıflandırılır?

A) En az yetki: veritabanı hesabından DROP yetkisini kaldıran ayar
B) Birincil kontrol: tek başına SQL injection'ı tamamen önleyen savunma
C) Kara liste: tehlikeli karakterleri tek tek tespit edip silen filtre
D) Destek kontrolü: allow-list ile beklenen biçimi zorlayan girdi doğrulama
E) Ek katman: bilinen saldırı kalıplarını sitenin önünde filtreleyen bir WAF kuralı

101. Bir belediyenin web uygulaması veritabanına, tabloları silme (DROP) ve başka kullanıcılara yetki verme (GRANT) haklarına sahip yönetici hesabıyla bağlanıyor. Denetçi Recep bu hesabın yetkilerinin daraltılmasını öneriyor. Bu önerinin SQL injection açısından sağladığı fayda nedir?

A) Uygulamanın tüm trafiğini şifreleyerek dinlenmeyi önler
B) Sorguyu parametreli hâle getirerek açığı tamamen kapatır
C) Açık istismar edilse bile ihlalin etkisini sınırlar
D) Saldırganın girdisini tarayıcıda çalışmaktan alıkoyar
E) Hatalı giriş denemelerini otomatik olarak IDS'e bildirir

102. Bir kooperatifin web sitesinde, hatalı bir arama yapıldığında ekrana tablo adlarını ve sorgunun bir bölümünü içeren ayrıntılı bir veritabanı hata mesajı çıkıyor. Yönetici Sinem, bu durumun SQL injection riskini artırıp artırmadığını soruyor. En doğru değerlendirme hangisidir?

A) Hata mesajı veritabanını şifrelediği için tablo adlarını görmek risk taşımaz
B) Yapıyı ele verdiği için mesaj gizlenmeli, ayrıntı yalnızca loglanmalıdır
C) Ayrıntılı hata mesajı saldırganı caydırır; açık bırakılması güvenliği artırır
D) Ayrıntılı hata yalnızca XSS riskini etkiler; SQL injection ile ilgisi yoktur
E) Hata mesajı yalnızca geliştiriciye görünür; kullanıcıya hiçbir şekilde gösterilmez

103. Bir e-ticaret firmasında SQL injection bulgusu raporlandıktan sonra genel müdür Umut, “Kodu değiştirmeyelim; sitenin önüne bir WAF koyalım, sorun çözülür” diyor. Güvenlik sorumlusu Pelin'in sunuma dayanan en doğru cevabı hangisidir?

A) WAF yalnızca şifresiz HTTP'de çalışabilir; HTTPS kullanan sitelerde hiçbir etkisi kalmaz
B) WAF tüm girdiyi şifrelediği için açık kendiliğinden kapanmış olur
C) WAF kurulduğunda kodda parametreli sorgu kullanmak performansı bozar
D) WAF yalnızca DDoS saldırılarını durdurur; injection girdilerini görmez
E) WAF bilinen kalıpları süzen bir ek katmandır; asıl düzeltme parametreli sorgudur

104. Bir kampüs kütüphane uygulamasında yapılan adli incelemede Hüseyin, kitap arama kutusu üzerinden yapılan bir SQL injection ile arama sonuçlarına kullanıcılar tablosundaki e-posta ve parola özetlerinin de eklendiğini tespit ediyor. Sunumdaki üç SQLi sonucundan hangisi yaşanmıştır?

A) Veri sızdırma — başka tablolardan veri çekilmesi
B) Auth bypass — parola kontrolünün atlanması
C) CSRF — kurbanın oturumunun kullanılması
D) Yıkım/kontrol — tabloların silinmesi
E) Stored XSS — script'in veritabanına kaydı

105. Bir haber sitesinin yorum bölümünde Ilgın, bir yorumun içine gizlenmiş script'in veritabanına kaydedildiğini ve o haberi açan her okuyucunun tarayıcısında çalıştığını tespit ediyor. Bu XSS türü hangisidir ve sunumda neden en tehlikelisi sayılır?

A) Stored XSS; sayfayı açan herkeste çalıştığı için
B) Reflected XSS; yalnızca özel hazırlanmış linki tıklayanda çalıştığı için
C) DOM-based XSS; sunucuya hiç uğramadan yalnızca istemcide oluştuğu için
D) Reflected XSS; script veritabanına kaydedilip kalıcı hâle geldiği için
E) Stored XSS; yalnızca yorumu yazan kişinin tarayıcısında çalıştığı için

106. Bir bankanın müşterilerine, bankanın gerçek alan adını içeren ama parametre kısmına script gizlenmiş bir bağlantı e-postayla gönderiliyor. Bağlantıya tıklayan müşterinin tarayıcısında sayfa, parametredeki içeriği anında geri yansıtıyor; veritabanına hiçbir şey kaydedilmiyor. SOC analisti Cihan bu olayı hangi XSS türü olarak sınıflandırmalıdır?

A) Stored (kalıcı) XSS
B) DOM-based XSS
C) SQL Injection
D) CSRF
E) Reflected (yansıyan) XSS

107. Bir e-ticaret sitesinin tek sayfalık uygulamasında Nur, sayfa içi JavaScript'in adres çubuğundaki bir değeri doğrudan sayfaya yazdığını ve buna bağlı bir XSS açığı bulunduğunu tespit ediyor. Sunucu loglarında ise bu açıkla ilgili hiçbir istek izi yok. Bu açık en çok hangi türe uyar?

A) Reflected XSS
B) Stored XSS
C) DOM-based XSS
D) Server-Side Request Forgery
E) SQL Injection

108. Bir forum yazılımında stored XSS açığı bulunuyor: kullanıcı yorumları sayfaya olduğu gibi basılıyor. Geliştirici Kemal'e açığın çekirdek çözümü soruluyor. Sunumdaki XSS savunma slaytına göre birincil çözüm hangisidir?

A) Forum veritabanı hesabından DROP yetkisini kaldırmak
B) Yorum formuna anti-CSRF token alanı eklemek
C) Forumu HTTP'den HTTPS'e taşıyıp HSTS açmak
D) Yorumları veritabanına parametreli sorgu kullanarak kaydetmek
E) Yorumu basılacağı bağlama göre kaçırmak (çıktı kodlama)

109. Bir hastane randevu sisteminin oturum çerezinin tarayıcıdaki JavaScript ile okunabildiği ve şifresiz bağlantılarda da gönderildiği tespit ediliyor. Güvenlik ekibinden Funda, XSS ile çerez çalınmasını zorlaştırmak için çereze hangi bayrakların eklenmesini önermelidir?

A) Cache-Control ve ETag
B) Expires ve Max-Age
C) Path=/ ve Domain
D) HttpOnly ve Secure
E) SameSite=None ve Domain

110. Bir belediyenin e-hizmet portalında çıktı kodlaması yapılmış olsa da güvenlik ekibi, gözden kaçan bir noktadan sayfaya script enjekte edilirse bunun da çalışmamasını istiyor. Eren, tarayıcıya hangi kaynaklardan script çalıştırabileceğini bildirip satır içi script'i kapatmayı öneriyor. Bu kontrol hangisidir?

A) SameSite çerez
B) Allow-list doğrulama
C) Content Security Policy (CSP)
D) Anti-CSRF token
E) Parametreli sorgu

111. Bir kargo firmasının BT sorumlusu Tülay, ekip için XSS savunma kontrol listesi hazırlıyor. Aşağıdakilerden hangisi sunumdaki XSS savunma önlemleri arasında YER ALMAZ?

A) Bağlama duyarlı çıktı kodlama
B) Oturum çerezinde HttpOnly ve Secure bayrakları
C) Destek olarak girdi doğrulama
D) DB hesabından DROP/GRANT yetkisinin alınması
E) Content Security Policy (CSP) tanımı

112. Bankacılık müşterisi Sedat, internet şubesinde oturumu açıkken aynı tarayıcıda bir kampanya sayfasını ziyaret ediyor. Sonradan, o sırada hesabından haberi olmadan bir para transferi yapıldığı ortaya çıkıyor. İnceleme, isteğin Sedat'ın tarayıcısından ve geçerli oturum çereziyle geldiğini, banka sunucusunda token kontrolü olmadığını gösteriyor. Bu saldırı hangisidir?

A) Server-Side Request Forgery
B) CSRF (Cross-Site Request Forgery)
C) SQL Injection
D) Stored XSS
E) Reflected XSS

113. Bir bankanın geliştirme ekibinden Beril, para transferi formunun başka sitelerden tetiklenebildiğinin raporlanması üzerine düzeltme planı hazırlıyor. Sunumdaki karşılaştırma tablosuna göre CSRF için birincil savunma hangisidir?

A) Ayrıntılı hata mesajlarını gizleme
B) Çıktı kodlama ve CSP tanımı
C) Bağımlılıkları düzenli güncelleme
D) Anti-CSRF token ve SameSite çerez
E) Parametreli sorgu ve en az yetki

114. Güvenlik farkındalığı eğitiminde Gonca, katılımcılara CSRF'i XSS ile karşılaştıran ifadeler veriyor. Aşağıdaki ifadelerden hangisi sunuma göre CSRF için doğru DEĞİLDİR?

A) Sunucuda anti-CSRF token kontrolü yoksa sahte istek sunucuya meşru görünür
B) Tarayıcının çerezi isteğe otomatik eklemesinden yararlanır
C) İstek kurbanın haberi olmadan başka bir sayfadan tetiklenir
D) Kurbanın açık oturumu üzerinden istek dışı işlem yaptırır
E) Kurbanın tarayıcısında saldırganın script'ini çalıştırıp çerezi çalar

115. Ara sınava hazırlanan Oya, sunumdaki “hafıza kancası”nı kullanarak üç açığı hedefleriyle eşleştiriyor. Aşağıdaki eşleştirmelerden hangisi doğrudur?

A) SQLi → sunucu (veritabanı) · XSS → açık oturum · CSRF → kullanıcının tarayıcısı
B) SQLi → kullanıcının tarayıcısı · XSS → açık oturum · CSRF → sunucu (veritabanı)
C) SQLi → sunucu (veritabanı) · XSS → kullanıcının tarayıcısı · CSRF → açık oturum
D) SQLi → açık oturum · XSS → sunucu (veritabanı) · CSRF → kullanıcının tarayıcısı
E) SQLi → kullanıcının tarayıcısı · XSS → sunucu (veritabanı) · CSRF → açık oturum

116. Bilgisayar programcılığı öğrencisi Oğulcan, DVWA labında öğrendiği SQLi ve XSS denemelerini üniversitenin gerçek öğrenci bilgi sistemi üzerinde “sadece test etmek için” yapmayı düşünüyor. Sunumdaki lab uyarısına göre en doğru yaklaşım hangisidir?

A) Gerçek sistemi okul ağı yerine evdeki internetten test etmek
B) Denemeleri yalnızca kendi makinesinde izole çalışan DVWA'da yapmak
C) Gerçek sistemde yalnızca Security level Low gibi zararsız denemeler yapmak
D) Gerçek sistemde denemek ama hiçbir kaydı değiştirmeden çıkmak
E) Gerçek sistemde denemek ama bulduğu açığı hemen bilgi işleme bildirmek

5. HAFTA · OWASP Top 10 — Bölüm 2

117. Bir yazılım firmasında güvenlik eğitimi veren Gökhan, katılımcılara OWASP Top 10 (2021) listesinde 1 numarada hangi riskin yer aldığını ve sunuma göre bunun nedenini soruyor. Doğru cevap hangisidir?

A) Security Misconfiguration; varsayılan parolalar hiçbir kurulumda değiştirilmez
B) Server-Side Request Forgery; bulut ortamlarında metadata servisleri herkese açıktır
C) Broken Access Control; test edilen uygulamaların çoğunda bir biçimine rastlanır
D) Injection; veritabanı kullanan her uygulama SQL injection'a karşı savunmasızdır
E) Cryptographic Failures; uygulamaların çoğu hâlâ şifresiz HTTP kullanmaktadır

118. Bir kooperatifin üye portalında, standart üye Sevda'nın adres çubuğundaki profil numarasını 42'den 43'e değiştirdiğinde başka bir üyenin iletişim bilgilerini görebildiği raporlanıyor. Sevda'nın rolü değişmemiş, yönetici işlevlerine de erişmemiştir. Bu bulgu hangi yetki yükseltme türüdür?

A) Dikey (vertical) yetki yükseltme
B) Yatay (horizontal) yetki yükseltme
C) Sunucu taraflı istek sahteciliği
D) Kayıtlı (stored) XSS
E) Oturum sabitleme (session fixation)

119. Bir belediyenin e-hizmet uygulamasında, standart bir vatandaş hesabıyla, menüde görünmeyen ama adı tahmin edilen bir yönetici adresine kullanıcı silme isteği gönderildiğinde işlemin başarıyla gerçekleştiği tespit ediliyor. Denetçi Tamer bu bulguyu nasıl sınıflandırmalıdır?

A) Yatay yetki yükseltme; kullanıcı başka bir vatandaşın kaydını görüyor
B) SSRF; sunucu kullanıcının verdiği adrese kendi adına istek atıyor
C) CSRF; silme isteği kurbanın haberi olmadan başka siteden tetikleniyor
D) Dikey yetki yükseltme; sunucu isteği yapanın rolünü doğrulamıyor
E) SQL injection; silme isteği veritabanı sorgusunun mantığını değiştiriyor

120. Bir e-ticaret sitesinin geliştiricisi Nilay, yönetim panelindeki “Siparişi iptal et” butonunu normal kullanıcıların arayüzünden kaldırdıklarını ve bu yüzden artık yalnızca yöneticilerin sipariş iptal edebileceğini söylüyor. Sunuma göre bu yaklaşımın sorunu nedir?

A) Butonun gizlenmesi sipariş verilerinin veritabanında açık metin olarak saklanmasına neden olur
B) Butonu gizlemek yalnızca mobil uygulamada işe yarar, web sitesinde işe yaramaz
C) Butonu gizlemek kontrol değildir; istek elle gönderilirse sunucu yine işleyebilir
D) Arayüzden kaldırılan butonlar tarayıcı önbelleğinde kalarak XSS'e yol açar
E) Buton gizlendiğinde yöneticiler de işlevi kullanamaz hâle gelir ve iş durur

121. Bir hastanenin randevu sisteminde yapılan yetkili testte İsmail, menüde hiçbir bağlantısı olmayan /admin yolunu tarayıcıya elle yazarak yönetim paneline ulaşabildiğini görüyor. Panel, yalnızca bağlantının gizlenmesiyle korunuyormuş. Sunumdaki zafiyet kalıpları tablosuna göre bu hangisidir?

A) Force browsing
B) IDOR
C) DNS rebinding
D) Eksik metot kontrolü
E) Parametre kurcalama

122. Bir kargo firmasının şube uygulamasında Aysel, giriş sonrası tarayıcıya gönderilen istekte kullanıcının rolünün bir parametre olarak taşındığını ve sunucunun yetki kararını bu değere göre verdiğini görüyor. Sunuma göre bu tasarımın kusuru ve doğru düzeltme hangisidir?

A) Yetki istemci verisine dayanıyor; rol sunucuda oturumdan okunmalı
B) Rol değeri açık metin; yalnızca Base64 ile kodlanarak taşınmalı
C) Rol parametresi tek; iki ayrı parametreye bölünürse sorun kalmaz
D) Rol parametresi GET ile gidiyor; POST gövdesine taşınması yeterli
E) Rol değeri kısa; tahmin edilmesin diye rastgele bir dizeye çevrilmeli

123. Bir bankanın iç uygulamasında yapılan yetkili testte Erhan, müşteri kayıtlarını görüntüleme (GET) isteğinin yetkisiz kullanıcıya kapalı olduğunu, ancak aynı adrese yapılan DELETE isteğinin yetki sorulmadan çalıştığını tespit ediyor. Bu kalıp ve doğru önlem hangisidir?

A) SSRF; sunucunun dış adreslere attığı istekler allow-list ile sınırlanmalı
B) Parametre kurcalama; DELETE isteği Base64 ile kodlanmalı
C) IDOR; kayıt numaraları tahmin edilemeyen değerlere çevrilmeli
D) Eksik metot kontrolü; yetki kontrolü tüm HTTP metotlarına uygulanmalı
E) Force browsing; yönetim yolları menüden tamamen kaldırılmalı

124. Bir KOBİ'nin müşteri portalını yeniden yazan ekipte Fadime, tüm erişim kontrolü hatalarını tek bir ilkeyle önlemek istiyor. Sunumdaki “altın kural” hangisidir?

A) Yetki kararı tarayıcıda verilir; sunucu yalnızca gelen sonucu kaydeder
B) Yetki kararı istekteki rol parametresine göre her istekte yeniden verilir
C) Yetki kararı menüdeki bağlantılar gizlenerek arayüz tarafında uygulanır
D) Yetki kararı her zaman sunucuda, her istekte, oturum kimliğine göre verilir
E) Yetki kararı yalnızca girişte bir kez verilir ve tüm oturum boyunca geçerli kalır

125. Bir belediyenin yeni API'sini tasarlayan Serdar, açıkça izin verilmemiş her isteğin reddedilmesini, yeni eklenen bir uç noktanın da varsayılan olarak kapalı gelmesini istiyor. Sunumdaki özet tablosunda bu yaklaşım nasıl adlandırılır?

A) Güvenlik için gizleme (obscurity)
B) Oturum sabitleme (session fixation)
C) İzin ver-varsayılan (allow by default)
D) Reddet-varsayılan (deny by default)
E) Kara liste (block list) yaklaşımı

126. Bir kargo firmasının API'sinde, kullanıcının adres çubuğundaki fatura numarasını değiştirerek başka bir müşterinin faturasına ulaşabildiği tespit ediliyor; isteği yapan kişinin oturum çerezi kendi hesabına ait. Sunuma göre bu zafiyetin adı ve OWASP'taki yeri hangisidir?

A) SSRF; A10 Server-Side Request Forgery kategorisi
B) Stored XSS; A03 Injection kategorisinin bir türü
C) IDOR; A01 Broken Access Control'ün bir alt türü
D) CSRF; A07 Auth & Session Failures kategorisi
E) SQL Injection; A03 Injection kategorisinin bir türü

127. Bir e-ticaret sitesinin yetkili testinde Zehra, kendi oturumuyla /api/invoice/1001 isteğini /api/invoice/1000 olarak değiştirip tekrar gönderiyor ve sunucudan “200 OK” ile başka bir müşterinin adını ve tutarını içeren bir yanıt alıyor. Bu yanıtla ilgili en doğru yorum hangisidir?

A) Yanıt yalnızca önbellekten geldiği için gerçek bir veri sızıntısı yoktur
B) Yanıt yalnızca 1000 numaralı kayda özgüdür; diğer id'ler etkilenmez
C) Doğru yanıt 302 Found olmalıydı; sunucu giriş sayfasına yönlendirmeliydi
D) 200 OK zafiyetin kanıtıdır; doğru yanıt 403 Forbidden olmalıydı
E) 200 OK sunucunun isteği reddettiğini gösterir; bulgu yoktur

128. IDOR bulgusu raporlanan bir belediye uygulamasında yazılım ekibinden Bülent, fatura numaralarını sıralı sayılar yerine rastgele ve uzun değerlere çevirmeyi tek çözüm olarak öneriyor. Sunuma göre bu önerinin değerlendirmesi hangisidir?

A) Rastgele id tahmin edilemeyeceği için IDOR kalıcı olarak çözülmüş olur
B) Rastgele id veritabanını şifrelediği için kayıtlar zaten okunamaz
C) Bu gizlemedir, kontrol değildir; her istekte sahiplik doğrulanmalıdır
D) Rastgele id kullanılırsa sunucunun 403 dönmesine gerek kalmaz
E) Rastgele id yalnızca dikey yetki yükseltmeyi önler, yatayı önlemez

129. Kod incelemesi yapan Gülşen, fatura uç noktasında şu mantığı görüyor: kayıt yalnızca URL'deki id ile veritabanından bulunuyor ve doğrudan kullanıcıya döndürülüyor; oturumdaki kullanıcı bilgisi hiç kullanılmıyor. Sunumdaki “sağlam” örneğe göre eklenmesi gereken kontrol hangisidir?

A) id'nin yalnızca rakam olup olmadığını kontrol edip geçmek
B) Kaydı döndürmeden önce SHA-256 özetini hesaplayıp eklemek
C) Uç noktayı menüden kaldırıp yalnızca mobil uygulamanın API'si üzerinden sunmak
D) Kaydın sahibi oturumdaki kullanıcı değilse 403 Forbidden döndürmek
E) URL'deki id'yi Base64 ile kodlayıp kayıttan sonra çözmek

130. Bir bankanın iç uygulama güvenliği ekibine katılan Ercan'a, yetkili testlerde tarayıcı ile sunucu arasına girip her HTTP isteğini durdurabilen, okuyup değiştirerek yeniden gönderebilen bir araç kullanacağı söyleniyor. Sunumda bu araç nasıl tanımlanır?

A) Wireshark — ağ arayüzünde pasif paket yakalayıcı
B) Burp Suite — araya giren vekil (intercepting proxy)
C) OpenSSL — şifreleme ve imza için komut satırı aracı
D) DVWA — kasıtlı olarak savunmasız bırakılmış web uygulaması
E) Nmap — port ve servis keşfi yapan tarayıcı

131. Juice Shop labında Hatice, Proxy ile yakaladığı tek bir API isteğini, her seferinde yalnızca bir değeri değiştirerek elle tekrar tekrar göndermek ve yanıtları yan yana karşılaştırmak istiyor. Sunuma göre bu iş için en uygun Burp modülü hangisidir?

A) Repeater
B) Decoder
C) Proxy
D) Intruder
E) Comparer

132. Bir e-ticaret firmasının SOC ekibinde Cengiz, tek bir müşteri oturumundan iki dakika içinde /api/invoice/1000'den /api/invoice/2000'e kadar sıralı yüzlerce istek yapıldığını ve hepsinin 200 OK döndüğünü görüyor. Bu tablo en çok neye işaret eder ve ilk değerlendirme ne olmalıdır?

A) Otomatik id taraması; erişim kontrolü yoksa faturalar toplu çekiliyor olabilir
B) Normal müşteri davranışı; kullanıcı geçmiş yıllara ait kendi faturalarını indiriyor
C) Sunucu taraflı istek sahteciliği; sunucu iç adreslere istek atıyor
D) DDoS saldırısı; sunucu kapasitesi artırılarak sorun çözülebilir
E) Yedekleme işi; fatura arşivi gece otomatik olarak kopyalanıyor

133. Kendi izole laboratuvarında Juice Shop kuran Belgin, tarayıcısını Burp'e yönlendiriyor; ancak HTTPS sayfalarda tarayıcı sertifika uyarısı veriyor ve trafiği göremiyor. Sunumdaki kurulum notuna göre eksik olan adım hangisidir?

A) Burp'ün Intruder modülünü Professional sürüme yükseltmek
B) Juice Shop'u HTTPS yerine Telnet üzerinden çalıştırmak
C) Juice Shop'un portunu 3000'den 443'e taşımak
D) Tarayıcıda tüm çerezleri silip gizli sekme açmak
E) Tarayıcının Burp'ün CA sertifikasına güvenmesini sağlamak

134. Bir kampüs uygulamasının “bağlantı önizleme” özelliğinde, kullanıcının verdiği adrese isteği sunucunun kendisi atıyor. Güvenlik ekibinden Mustafa, saldırganın bu özellikle dışarıdan erişilemeyen iç yönetim paneline ulaşabildiğini fark ediyor. Sunuma göre bu saldırı güvenlik duvarını neden aşabilir?

A) Saldırgan güvenlik duvarının parolasını tahmin ettiği için
B) Saldırganın tarayıcısı iç ağda bulunan bir cihaz olduğu için
C) İstek sunucudan çıktığı için güvenlik duvarını içeriden aşar
D) Güvenlik duvarı yalnızca UDP trafiğini denetleyebildiği için
E) İstek şifreli olduğu için güvenlik duvarı içeriği göremez

135. Bir hastanenin web uygulamasını gözden geçiren Şeyma, SSRF riski açısından öncelikle hangi özellikleri incelemesi gerektiğini listeliyor. Sunuma göre aşağıdaki özellik gruplarından hangisi SSRF için tipik risk noktalarıdır?

A) Yorum kutusu, profil açıklaması, forum mesajı ve arama alanı
B) Bağlantı önizleme, web kancası, PDF üretimi ve URL'den resim çekme
C) Veritabanı yedeği, log döndürme, disk şifreleme ve DLP
D) Port tarama, paket yakalama, IDS imzası ve VLAN ayrımı
E) Giriş formu, parola sıfırlama, oturum çerezi ve çıkış düğmesi

136. Bulutta çalışan bir e-ticaret uygulamasında yapılan incelemede Necati, önizleme özelliği üzerinden sunucunun 169.254.169.254 adresine istek attırıldığını ve yanıtta geçici erişim anahtarlarının döndüğünü tespit ediyor. Olay müdahalesinde öncelikli adım hangisi olmalıdır?

A) Sızan geçici anahtarları iptal edip yenilemek ve hesaptaki işlemleri incelemek
B) Yalnızca uygulamanın şifresiz HTTP sürümünü kapatıp beklemek
C) Önizleme özelliğinin yazı tipini değiştirip kullanıcılara duyuru yapmak
D) Anahtarlar zaten geçici olduğu için hiçbir işlem yapmadan sürelerinin dolmasını beklemek
E) Sunucunun disk alanını artırıp uygulamayı yeniden başlatmak

137. Bir belediyenin bulut altyapısını yöneten Lale, uygulama sunucularının metadata servisine giden isteklerini sıkılaştırmak istiyor. Sunumdaki SSRF savunma adımlarına göre metadata erişimi için önerilen önlem hangisidir?

A) Metadata adresini başka bir IP'ye taşıyıp yeni adresi ekip dışında kimseyle paylaşmamak
B) Link-local adrese çıkışı ağda engellemek ve IMDSv2 token zorunluluğunu açmak
C) Metadata servisine giden istekleri yalnızca loglayıp hiç engellememek
D) Metadata yanıtlarını Base64 ile kodlayıp uygulamaya öyle iletmek
E) Metadata servisine yalnızca HTTP yerine HTTPS ile bağlanılmasını sağlamak

138. SSRF bulgusu raporlanan bir kargo firmasında geliştirici Yavuz, “Metadata adresini içeren URL'leri engelleyen bir kara liste yazdık, sorun çözüldü” diyor. Sunuma göre bu yaklaşımın sorunu ve önerilen ana savunma hangisidir?

A) Kara liste yerine sunucunun yaptığı tüm istekler Base64 ile kodlanmalıdır
B) Kara liste yeterlidir; yalnızca liste her gün elle güncellenmelidir
C) Kara liste çok güçlü olduğu için meşru kullanıcıları da engeller; tamamen kaldırılmalıdır
D) Kara liste yalnızca IDOR'u önler; SSRF için anti-CSRF token eklenmesi gerekir
E) Kara listeler kolayca atlatılır; yalnızca onaylı hedeflere izin veren allow-list gerekir

139. Bir bankanın PDF rapor üreten servisinde allow-list uygulanıyor. Güvenlik mimarı Sema, ayrıca URL'deki alan adı DNS ile çözüldükten sonra elde edilen IP'nin iç ya da özel ağ aralığına düşüp düşmediğinin kontrol edilmesini istiyor. Sunuma göre bu ek kontrolün amacı nedir?

A) Kullanıcının IP adresini kaydederek KVKK kapsamındaki yükümlülüğü yerine getirmek
B) DNS sorgularını şifreleyerek kimin hangi siteye gittiğini gizlemek
C) Sunucunun DNS önbelleğini temizleyerek performansı artırmak
D) Sunucunun yalnızca IPv6 adreslerine bağlanmasını zorunlu kılmak
E) Onaylı görünen bir adın iç ağ IP'sine çözülmesine karşı korumak (DNS rebinding)

140. Bir e-ticaret sitesinin “URL'den ürün görseli al” özelliğinde, sunucunun çektiği içeriği kullanıcıya olduğu gibi geri gösterdiği ve yönlendirmeleri (3xx) kendiliğinden takip ettiği tespit ediliyor. Ömer, sunumdaki dördüncü SSRF savunma adımını uygulamak istiyor. Bu adım hangisidir?

A) Çekilen içeriği ham olarak döndürmemek ve 3xx yönlendirmelerini takip etmemek
B) Çekilen içeriği kullanıcıya göstermeden önce SHA-256 özetini eklemek
C) Çekilen içeriği önbellekte daha uzun süre tutarak sunucu yükünü azaltmak
D) Görsel alma isteklerini yalnızca kayıtlı müşteriler için açık tutmak
E) Yönlendirmeleri takip etmeye devam edip yalnızca yanıt sürelerini ayrıntılı loglamak

141. Bir belediyenin yazılım ekibinde Feride, SSRF için kontrol listesi hazırlıyor. Aşağıdakilerden hangisi sunumdaki SSRF savunma adımları arasında YER ALMAZ?

A) Onaylı hedefler için allow-list kullanmak
B) Çekilen içeriği kullanıcıya ham döndürmemek
C) Metadata adresine çıkışı ağda engellemek
D) Çözümlenen IP'nin iç ağda olup olmadığını denetlemek
E) Oturum çerezine SameSite bayrağı eklemek

142. Ara sınav tekrarında Kenan, sunumdaki “bölümü bağla” tablosunu tek cümleye indirmek istiyor. Broken Access Control, IDOR ve SSRF'in ortak kök nedeni sunuma göre hangisidir?

A) Uygulamanın eski sürüm bir kütüphane kullanması ve yamaların gecikmesi
B) Kullanıcı parolalarının veritabanında tuzsuz ve hızlı bir hash ile saklanması
C) Web sunucusunun şifresiz HTTP kullanması ve trafiğin dinlenebilmesi
D) Tarayıcının kullanıcı girdisini HTML'e kaçırmadan sayfaya basması
E) Sunucunun istemciden gelen referansa ya da hedefe güvenip kontrolü atlaması

143. Bilgisayar programcılığı öğrencisi Arzu, kargo takip sitesinde kendi gönderisini sorgularken numarayı yanlış yazınca başka birinin adını ve adresini gördüğünü fark ediyor. Merak edip başka numaraları da denemeyi düşünüyor. Sunumdaki hukuki uyarıya göre Arzu için en doğru davranış hangisidir?

A) Sitenin açığı kendi hatası olduğu için denemeye devam etmek
B) Başka numara denemeden durmak ve durumu firmaya bildirmek
C) Intruder ile tüm numaraları tarayıp sonuçları firmaya göndermek
D) Açığı kanıtlamak için birkaç numara daha deneyip ekran görüntüsü almak
E) Bulduğu bilgileri sosyal medyada paylaşarak firmayı uyarmak

144. Juice Shop labını tamamlayan Turgay, sunumdaki dördüncü adım için bir IDOR bulgusu raporu yazıyor. Sunuma göre raporun üç cümlesinde mutlaka yer alması gereken bilgiler hangisidir?

A) Hangi araç, hangi sürüm, hangi işletim sistemi
B) Hangi port, hangi protokol, hangi MAC adresi
C) Hangi parola, hangi hash, hangi salt değeri
D) Hangi tarayıcı, hangi tema, hangi ekran boyutu
E) Hangi istek, ne değiştirildi, beklenen ve gerçek cevap

6. HAFTA · Kimlik & Erişim Yönetimi

145. Bir hastanenin bilgi sisteminde hemşire Cemre, kendi kullanıcı adı, parolası ve kartıyla sisteme başarıyla giriyor; ancak eczane stok ekranını açmak istediğinde “Bu sayfaya erişim yetkiniz yok” uyarısı alıyor. Bu iki adım sırasıyla hangi kavramlara karşılık gelir?

A) Önce hesap verebilirlik (accountability), sonra inkâr edilemezlik
B) Önce yetkilendirme (authorization), sonra kimlik doğrulama (authentication)
C) Önce kimlik doğrulama (authentication), sonra yetkilendirme (authorization)
D) İki adım da kimlik doğrulamadır; yalnızca farklı ekranlarda yapılmıştır
E) İki adım da yetkilendirmedir; giriş ekranı yalnızca rol seçimi yapar

146. Bir bankanın şube personeli, bilgisayarlarına giriş yaparken parolalarına ek olarak parmak izi okutuyor. BT sorumlusu Atakan, yeni gelen personele parmak izinin hangi faktör ailesine girdiğini anlatıyor. Doğru cevap hangisidir?

A) Sahip olduğun şey (cihaz)
B) Bildiğin şey (bilgi)
C) Olduğun şey (biyometri)
D) Bulunduğun yer (konum)
E) Yaptığın şey (davranış)

147. Bir belediyenin e-posta sisteminde güvenliği artırmak isteyen yönetici, kullanıcılardan girişte önce parolalarını, ardından ikinci bir ekranda ayrı bir “güvenlik parolası” girmelerini istiyor ve bunu “iki faktörlü doğrulama” olarak duyuruyor. Denetçi Gülay'ın bu uygulamayla ilgili tespiti ne olmalıdır?

A) İki kanıt da aynı aileden (bildiğin şey) olduğu için bu MFA sayılmaz
B) İkinci parola daha uzun olduğu sürece uygulama MFA kabul edilir
C) İki ayrı ekranda istendiği için bu uygulama tam anlamıyla MFA'dır
D) Bu uygulama MFA'dır; ancak yalnızca mobil cihazlarda geçerli sayılır
E) İki parola birlikte biyometrik doğrulamanın yerini tutabilir

148. Bir kargo firmasının muhasebe müdürü, banka hesabına SMS ile gelen kodla giriş yapıyordu. Bir gün telefonu aniden şebekeden düşüyor; o sırada saldırganın operatörden aynı numaraya yeni SIM kart çıkardığı ve kodları aldığı anlaşılıyor. BT sorumlusu Sarp, sunuma göre bu olayı nasıl değerlendirmelidir?

A) SIM-swap saldırısıdır; SMS OTP en zayıf MFA yöntemidir
B) Brute force saldırısıdır; parola uzatılırsa sorun tamamen çözülür
C) Phishing saldırısıdır; TOTP kullanılsaydı kesin olarak önlenirdi
D) IDOR saldırısıdır; hesap numaraları rastgele yapılmalıydı
E) CSRF saldırısıdır; çerezlere SameSite eklenmesi yeterli olurdu

149. Bir e-ticaret firmasında yöneticilerin hesaplarına sahte giriş sayfalarıyla oltalama saldırıları yapılıyor. Güvenlik sorumlusu Melek, bir kullanıcı sahte siteye girse bile kimlik bilgisinin işe yaramamasını sağlayacak, sunumda “altın standart” olarak geçen yöntemi öneriyor. Bu yöntem hangisidir?

A) Güvenlik sorusu ve PIN birlikte
B) WebAuthn / FIDO2 donanım anahtarı
C) Daha uzun ve karmaşık bir parola
D) TOTP uygulamasıyla 6 haneli kod
E) SMS ile tek kullanımlık kod

150. Kampüs BT biriminden Tunahan, öğretim elemanlarına TOTP uygulamasının nasıl çalıştığını anlatıyor. Bir hoca, “Uçakta internetim yokken kod nasıl üretiliyor?” diye soruyor. Sunuma göre doğru açıklama hangisidir?

A) Kod, kullanıcının parolasının SHA-256 özetinin son altı hanesidir
B) Kod, telefonun SIM kartında saklanan sabit bir listeden sırayla okunur
C) Kod, paylaşılan gizli anahtar ve zamandan HMAC ile türetilir; saat senkronu yeter
D) Kod her 30 saniyede bir sunucudan uygulamaya şifreli olarak gönderilir
E) Kod internet yokken üretilemez; uygulama en son sunucudan gelen kodu tekrar gösterir

151. Bir belediyenin TOTP doğrulama servisinin loglarını inceleyen Nermin, telefonunun saati birkaç saniye geri kalan bir kullanıcının kodunun yine de kabul edildiğini, rastgele girilen bir kodun ise reddedilip deneme sayacının artırıldığını görüyor. Bu davranışla ilgili en doğru yorum hangisidir?

A) Sunucu saat farkı olan her kodu reddetmesi gerekirken hata yapıyor
B) Deneme sayacı yalnızca doğru kodlarda artırılarak kullanıcı ödüllendiriliyor
C) Sunucu ±1 zaman adımı tolerans tanıyor; eşleşmeyen kodu reddedip sayıyor
D) Sunucu kodu kabul ettiği için TOTP'nin gizli anahtarı sızmış olmalı
E) Sunucu TOTP kodlarını hiç kontrol etmeyip yalnızca parolaya bakıyor

152. Bir KOBİ'nin destek hattına, TOTP kullanan bir çalışanın sahte bir giriş sayfasına hem parolasını hem de o anki 6 haneli kodunu yazdığı ve hesabının aynı dakika içinde ele geçirildiği bildiriliyor. Rıdvan, sunumdaki güvenlik notuna göre bu olayı nasıl açıklamalıdır?

A) TOTP kodu yalnızca 30 saniye geçerli olduğundan saldırganın kodu kullanması imkânsızdır
B) TOTP kodu çevrimdışı üretildiği için saldırgan kodu hiçbir şekilde kullanamaz
C) Saldırgan TOTP'nin gizli anahtarını sahte sayfadan doğrudan okumuş olmalıdır
D) TOTP sağlamdır ama phishing'e karşı tam koruma vermez; kod anında kullanılabilir
E) Olay SIM-swap'tir; TOTP kodları SMS ile gönderildiği için ele geçirilmiştir

153. Bir kooperatifin üyelik sisteminde parolalar bcrypt ile saklanıyor. Üye Özlem, 90 karakterlik bir parola belirliyor; daha sonra yazılımcı Bilge, parolanın ilk 72 baytı doğru olup sonu farklı girildiğinde de girişin kabul edildiğini fark ediyor. Sunumdaki karşılaştırma tablosuna göre bunun nedeni nedir?

A) bcrypt deterministik olmadığı için farklı parolalar aynı özeti verebilir
B) bcrypt salt kullanmadığı için uzun parolalar birbirine karışır
C) Sistem parolayı açık metin saklıyor; bcrypt hiç devreye girmiyor
D) bcrypt bir şifreleme algoritması olduğu için anahtar uzunluğu sınırlıdır
E) bcrypt girdiyi ~72 baytta sessizce keser; uzun parolada bu bir tuzaktır

154. Yeni bir e-ticaret projesinin mimarı Haluk, parola depolama algoritmasını seçerken saldırganların GPU çiftlikleriyle tahmin denemesini pahalılaştırmak istiyor. Sunuma ve OWASP önerisine göre yeni sistemde hangi algoritma tercih edilmeli ve neden?

A) AES-256; parolaları geri çözülebilir şekilde saklamayı mümkün kılar
B) argon2id; CPU'ya ek olarak bellek de tükettiği için GPU direnci yüksektir
C) MD5; en eski ve en çok denenmiş algoritma olduğu için güvenilirdir
D) SHA-256; çok hızlı olduğu için doğrulama sırasında sunucuyu yormaz
E) bcrypt; bellek-zor olduğu için GPU saldırılarına karşı en dirençli olandır

155. Bir bankanın kimlik servisinde bcrypt iş faktörü 12 olarak ayarlı. Güvenlik ekibinden Dilara, sunucu donanımı yenilendiği için değeri 13'e çıkarmayı öneriyor. Sunumdaki bcrypt açıklamasına göre bu değişikliğin etkisi nedir?

A) Salt uzunluğu bir karakter artar, maliyet değişmez
B) Her doğrulamanın maliyeti yaklaşık iki katına çıkar
C) Özet artık geri çözülebilir hâle gelir
D) Maliyet yalnızca yüzde bir oranında artar
E) Parolanın en fazla uzunluğu bir bayt artar

156. Bir belediye portalında Egemen, argon2id parametrelerini ayarlıyor. Çok yüksek değer seçildiğinde girişin birkaç saniye sürdüğünü, çok düşük değerde ise milisaniyenin altında kaldığını görüyor. Sunumdaki hedefe göre bir doğrulama sunucuda yaklaşık ne kadar sürmelidir?

A) Yaklaşık 50–250 ms
B) En az 1 dakika
C) 1 ms'nin altında
D) Tam olarak 30 saniye
E) Yaklaşık 2–5 saniye

157. Bir kampüs uygulamasının kod incelemesinde Sevim, giriş sırasında hesaplanan parola özetinin veritabanındakiyle karakter karakter karşılaştırıldığını ve ilk farklı karakterde döngünün hemen bittiğini görüyor. Sunumdaki “doğru” listesine göre bu karşılaştırma nasıl yapılmalıdır?

A) Sabit zamanlı (constant-time) bir karşılaştırma fonksiyonuyla
B) Özetleri MD5 ile yeniden özetleyip karşılaştırarak
C) Özetleri önce Base64'e çevirip karşılaştırarak
D) İlk farklı karakterde döngüden çıkarak, mümkün olan en hızlı şekilde
E) Özet yerine açık metin parolaları karşılaştırarak

158. Bir kooperatifin üyesi Kutay, bir fotoğraf baskı sitesine “Google ile giriş” seçeneğini kullanarak üye oluyor. Arkadaşı, “Google parolanı o siteye vermiş oldun” diyor. Sunumdaki OAuth 2.0 açıklamasına göre doğru durum hangisidir?

A) Parola şifrelenerek siteye iletilir; site onu yalnızca ilk girişte bir kez kullanır
B) Parola Google ve site arasında bölünerek ikisinde ayrı ayrı saklanır
C) Parola yalnızca Google'a verilir; siteye sınırlı bir access token verilir
D) Parolanın SHA-256 özeti siteye gider; site giriş için onu kullanır
E) Parola siteye açık metin gider ama site onu veritabanına kaydetmez

159. Bir belediyenin açık veri API'si OAuth 2.0 ile korunuyor. Mimari dokümanı hazırlayan Aslıhan, “Gelen access token'ı doğrulayıp korunan veriyi döndüren bileşen” için sunumdaki dört rolden hangisini yazmalıdır?

A) Authorization Server
B) Identity Provider
C) Resource Owner
D) Resource Server
E) Client

160. Bir e-ticaret sitesinin “Google ile giriş” entegrasyonunu inceleyen Deniz, Authorization Code akışının üçüncü adımında kısa ömürlü code'un access token ile takas edildiğini görüyor. Sunuma göre bu takas nerede ve nasıl yapılır?

A) Kaynak sunucuda, code doğrudan API isteğine eklenerek
B) Uygulamanın sunucusunda, code ve client_secret ile arka kanaldan
C) Kullanıcının telefonunda, code SMS ile gönderilerek
D) Kullanıcının tarayıcısında, client_secret sayfanın JavaScript koduna gömülerek
E) Kullanıcının tarayıcısında, code adres çubuğuna yazılarak

161. Bir kargo firması müşterileri için tek sayfalık bir web uygulaması (SPA) ve bir mobil uygulama geliştiriyor; ikisinde de güvenli bir şekilde saklanabilecek bir client_secret yok. Geliştirici Gülsüm, sunuma göre Authorization Code akışına neyi eklemelidir?

A) PKCE
B) CORS *
C) Base64
D) alg: none
E) SMS OTP

162. Bir hastanenin yazılım ekibinde İbrahim, “OAuth 2.0 kullanıyoruz, demek ki kullanıcının kim olduğunu da OAuth söylüyor” diyor. Ekip lideri Mine, sunumdaki “sık karışan nokta”yı hatırlatıyor. Mine'nin açıklaması hangisidir?

A) OAuth 2.0 bir şifreleme algoritmasıdır; kimlik için TLS sertifikası gerekir
B) OAuth 2.0 kimlik doğrulama protokolüdür; yetkilendirme için OIDC gerekir
C) OAuth 2.0 yalnızca SMS doğrulaması için kullanılan bir çerçevedir
D) OAuth 2.0 yalnızca parola hash'leme standardıdır; kimlikle ilgisi yoktur
E) OAuth 2.0 yetkilendirme çerçevesidir; kimlik için üstüne OIDC katmanı gelir

163. Bir mobil uygulamanın geliştiricisi Selçuk, kullanıcıya ait bazı bilgileri JWT'nin payload kısmına koymayı planlıyor. Sunumdaki “JWT şifreli değildir, sadece imzalıdır” uyarısına göre aşağıdakilerden hangisi payload'a konması uygun bir bilgi DEĞİLDİR?

A) Kullanıcının rolü (role)
B) Kullanıcının kredi kartı numarası
C) Token'ın üretildiği zaman (iat)
D) Kullanıcı kimliği (sub)
E) Token'ın bitiş zamanı (exp)

164. Bir kampüs uygulamasında öğrenci rolündeki bir kullanıcı, jwt.io'da kendi token'ının payload'ını çözüp role değerini “admin” yapıyor ve token'ı yeniden kodlayıp gönderiyor. Sunucu imzayı gizli anahtarıyla doğru biçimde doğruluyor. Ayşegül'e göre sonuç ne olur?

A) Payload base64 olduğu için yeni rol geçerli olur ve admin yetkisi alınır
B) Token yalnızca bitiş süresi dolana kadar admin yetkisiyle çalışmaya devam eder
C) İmza tutmayacağı için token reddedilir; içerik kurcalaması yakalanır
D) Role değeri değiştiğinde sunucu otomatik olarak yeni bir imza üretip onaylar
E) Sunucu token'ı kabul eder ama işlemleri yalnızca loglara yazmakla yetinir

165. Bir bankanın API'sinde yapılan yetkili güvenlik testinde, imzası silinmiş ve başlığındaki algoritma alanı “none” yapılmış bir token'ın kabul edildiği tespit ediliyor. Geliştirici Efe'ye sunuma göre önerilecek düzeltme hangisidir?

A) Token ömrünü uzatarak kullanıcıların daha az giriş yapmasını sağlamak
B) Algoritma alanını token'dan okumaya devam edip yalnızca none değerlerini loglamak
C) İzin verilen algoritmayı sunucuda sabitlemek; alg'ı token'dan okumamak
D) Token'ın payload'ını AES ile şifreleyip imzayı tamamen kaldırmak
E) Token'ı Base64 yerine Hex ile kodlayarak okunmasını zorlaştırmak

166. Bir e-ticaret sitesinin kod incelemesinde Pakize, JWT doğrulamasında imzanın kontrol edildiğini ama exp alanına hiç bakılmadığını görüyor. Bu eksikliğin en önemli sonucu nedir?

A) Payload içeriği şifrelenmediği için sunucu token'ı okuyamaz hâle gelir
B) Sunucu token'ı her istekte yeniden imzalamak zorunda kalır ve belirgin biçimde yavaşlar
C) Token'ın imzası her istekte geçersiz sayılır ve kimse giriş yapamaz
D) Süresi dolmuş, hatta çalınmış token'lar süresiz olarak geçerli kalabilir
E) Kullanıcıların rolleri her istekte rastgele olarak yeniden atanır

167. Bir belediye mobil uygulamasının mimarı Tayfun, kullanıcıların sık sık yeniden giriş yapmasını istemiyor ama çalınan bir token'ın uzun süre işe yaramasını da istemiyor. Sunumdaki token yaşam döngüsüne göre en uygun tasarım hangisidir?

A) Token yerine kullanıcı parolasının cihazda açık metin saklanması
B) Tek bir uzun ömürlü access token ve sunucuda iptal mekanizması olmayan bir oturum
C) Uzun ömürlü access token ile kısa ömürlü bir refresh token birlikte
D) Her API isteğinde kullanıcı adı ve parolanın yeniden gönderilmesi
E) Kısa ömürlü access token ile uzun ömürlü, iptal edilebilir refresh token

168. Kooperatif üyesi Nehir'in telefonu çalınıyor; uygulamada oturumu açık kalmıştı. Destek ekibinden Görkem, saldırganın oturumu uzun süre sürdürmesini engellemek istiyor. Sunumdaki token tasarımına göre en etkili adım hangisidir?

A) Nehir'den yeni bir kullanıcı adı seçmesini istemek
B) Tüm kullanıcıların parolalarını Base64 ile yeniden kodlamak
C) Sunucuda Nehir'e ait refresh token'ı iptal (revoke) etmek
D) Uygulamanın JWT algoritmasını HS256'dan none'a çevirmek
E) Nehir'in kısa ömürlü access token'ının süresini uzatmak

169. Bir KOBİ'nin kimlik servisinde, JWT imzalama anahtarının kaynak koda sabit olarak yazıldığı ve kodun herkese açık bir depoya gönderildiği fark ediliyor. BT sorumlusu Saadet, sunumdaki lab uyarısına göre durumun ciddiyetini nasıl açıklamalıdır?

A) Anahtar kodda olduğu için zaten şifrelidir; depoyu gizli yapmak yeterlidir
B) Sızan anahtar yalnızca parolaları etkiler; token'lar bundan etkilenmez
C) Yalnızca o güne kadar üretilmiş token'lar okunabilir; yeni token'lar güvendedir
D) Anahtar sızsa da imzalar Base64 olduğu için kimse yeni token üretemez
E) Anahtarı bilen herkes token üretebilir; anahtar yenilenmeli, .env'den okunmalı

170. Lab ödevinde Batın, giriş rotasını yazarken kullanıcının girdiği parolayı yeniden argon2id ile özetleyip veritabanındaki değerle düz metin olarak karşılaştırmayı düşünüyor; ancak aynı parola her seferinde farklı bir özet üretiyor. Sunumdaki lab adımlarına göre doğru yaklaşım hangisidir?

A) Özeti Base64'e çevirip girilen parolanın Base64 hâliyle kıyaslamak
B) Her kullanıcıya aynı sabit salt'ı verip özetleri eşit hâle getirmek
C) argon2id yerine salt'sız SHA-256 kullanıp özetleri eşitlemek
D) argon2.verify(hash, parola) ile kayıtlı özete karşı doğrulamak
E) Kayıtta parolayı açık metin de saklayıp girişte onunla kıyaslamak

171. Kampüs takvim uygulaması, öğrencilerin üniversite hesabına OAuth 2.0 ile bağlanıp yalnızca ders takvimlerini okumak istiyor. BT birimi sorumlusu Rüya, uygulamanın e-posta gönderme ya da dosya silme izni almasını istemiyor. Sunuma göre bu sınırlama hangi kavramla sağlanır?

A) Algoritma (alg)
B) Salt (tuz)
C) İş faktörü (cost)
D) Kapsam (scope)
E) Bitiş zamanı (exp)

172. Bir hastanenin eski kimlik sistemini denetleyen Ahu, sunumdaki parola depolama “doğru/yanlış” listesine göre bir rapor hazırlıyor. Aşağıdaki uygulamalardan hangisi parola depolamada KULLANILMAMALI?

A) Tüm kullanıcılar için aynı sabit salt değeri
B) Donanım hızına göre ayarlanan iş faktörü
C) Her kullanıcıya benzersiz rastgele salt
D) argon2id ile kasten yavaş özetleme
E) Doğrulamada sabit zamanlı karşılaştırma

7. HAFTA · Endpoint Güvenliği ve Malware Analizi Temelleri

173. Bir belediyenin SOC ekibinde Cemal, ağ izleme aracında bir muhasebe bilgisayarından bilinmeyen bir IP'ye 443/tcp üzerinden düzenli çıkış görüyor; ancak trafik şifreli olduğu için içeriği okuyamıyor ve bağlantıyı hangi programın açtığını bilemiyor. Sunuma göre bu boşluğu en iyi hangi görünürlük kapatır?

A) DNS önbelleği; bağlantının hangi kullanıcıya ait olduğunu gösterir
B) Port taraması; bilgisayardaki açık portlar listelenince süreç bulunur
C) Uç nokta görünürlüğü; bağlantıyı açan süreci ve süreç zincirini gösterir
D) Daha ayrıntılı ağ görünürlüğü; paket boyutlarından şifreli içerik çözülebilir
E) Güvenlik duvarı logu; şifreli trafiğin içeriğini düz metne çevirir

174. Bir kargo firmasında yıllardır yalnızca imza tabanlı klasik antivirüs kullanılıyor. BT sorumlusu Aynur, daha önce hiç görülmemiş ya da her bulaşmada kendini değiştiren zararlıların neden yakalanamadığını yönetime anlatıyor. Sunuma göre doğru açıklama hangisidir?

A) Klasik AV bilinen hash/parmak izini eşler; yeni ve polimorfik zararlıyı kaçırır
B) Klasik AV davranışa baktığı için çok fazla yanlış alarm üretip kapatılır
C) Klasik AV yalnızca Linux'ta çalıştığı için Windows'a özgü zararlıları hiç tanımaz
D) Klasik AV yalnızca ağ trafiğini izlediği için diskteki dosyaları göremez
E) Klasik AV makineyi ağdan izole ettiği için zararlı tespitten önce silinir

175. Bir bankanın şubelerinde kullanılan güvenlik yazılımı, imza veritabanında olmayan bir dosyayı özelliklerine ve davranış kalıplarına bakıp makine öğrenmesiyle puanlayarak şüpheli olarak işaretliyor. BT uzmanı Burcu, sunumdaki üç kuşaktan hangisini anlatmaktadır?

A) Yeni Nesil AV (NGAV) — sezgisel + makine öğrenmesi
B) WAF — web isteklerinde bilinen kalıp filtresi
C) Klasik Antivirüs (AV) — yalnızca imza tabanlı
D) IDS/IPS — yalnızca ağ imzası tabanlı tespit
E) Güvenlik duvarı (firewall) — port ve IP tabanlı

176. Bir hastanenin bilgi işlem müdürü Sertaç, yeni alınacak uç nokta çözümünden sürekli telemetri toplamasını, süreç zincirini izlemesini, uyarı üretmesini ve gerekirse makineyi ağdan izole edip süreci sonlandırabilmesini istiyor. Sunuma göre bu gereksinimleri karşılayan kuşak hangisidir?

A) Yeni Nesil AV
B) Kişisel güvenlik duvarı
C) Disk şifreleme
D) Klasik Antivirüs
E) EDR / XDR

177. Bir KOBİ'de EDR'a geçiş tartışılırken yönetici Hakkı, “EDR aldıysak imza tabanlı taramaya artık hiç gerek kalmadı, o kısım tamamen çöpe gidiyor” diyor. Sunumdaki “anahtar fikir”e göre doğru değerlendirme hangisidir?

A) Doğrudur; imza tabanlı tarama EDR ile birlikte çalışamaz
B) Kuşaklar birbirini iptal etmez, katmanlanır; EDR içinde imza ve ML hâlâ vardır
C) Doğrudur; EDR yalnızca davranışa bakar ve içinde hiçbir imza bileşeni bulunmaz
D) Yanlıştır; klasik AV EDR'dan daha yeni ve daha gelişmiş bir kuşaktır
E) Yanlıştır; EDR yalnızca imza kullanır, davranışa hiç bakmaz

178. Bir belediyede Sysmon kuran Yıldız, bir zararlının hangi programdan doğduğunu bulmak için süreç ağacını kurmak istiyor. Sunuma göre komut satırını ve üst süreci (parent) kaydeden, süreç ağacının temeli olan Sysmon olayı hangisidir?

A) Event ID 3 — Network Connection
B) Event ID 13 — Registry Value Set
C) DNS Query olayı
D) Event ID 11 — File Create
E) Event ID 1 — Process Create

179. SOC stajyeri Oktay, Sysmon kayıtlarında powershell.exe sürecinin 203.0.113.77 adresinin 443 portuna bağlandığını gösteren bir satır buluyor. Bu satır hangi Sysmon olayıdır ve analiste ne sağlar?

A) Event ID 3 — Network Connection; C2 trafiğini sürece bağlar
B) Event ID 1 — Process Create; ağ paketinin içeriğini düz metne çevirir
C) Event ID 1 — Process Create; yeni dosyanın diske yazıldığını gösterir
D) Event ID 11 — File Create; bağlantının şifre anahtarını kaydeder
E) Event ID 13 — Registry Value Set; IP adresinin sahibini çözümler

180. Bir muhasebe bilgisayarındaki Sysmon kayıtlarında Nuray, winword.exe'nin kullanıcının Temp klasörüne fatura.pdf.exe adında yeni bir dosya yazdığını gösteren bir olay görüyor. Bu olay türü ve neyi yakaladığı hangi seçenekte doğru verilmiştir?

A) File Create (Event ID 11); dropper'ın diske bıraktığı yükü yakalar
B) Registry Value Set (Event ID 13); dosyanın açılışta çalışacağını yakalar
C) DNS Query; dosyanın hangi alan adından çözümlendiğini yakalar
D) Network Connection (Event ID 3); dosyanın C2 sunucusuna gönderildiğini yakalar
E) Process Create (Event ID 1); dosyanın ağ üzerinden indirildiği IP'yi yakalar

181. Bir kooperatifin bilgisayarında yapılan incelemede Tuncay, powershell.exe'nin HKCU\…\Run altında "Updater" adlı bir değer oluşturduğunu gösteren Sysmon olayını buluyor. Bu bulgu en çok neye işaret eder?

A) Normal güncelleme; Windows her aylık güncellemede bu değeri kendisi oluşturuyor
B) Ağ taraması; Run anahtarı yerel ağdaki portları listeliyor
C) Parola özetleme; Run anahtarı kullanıcı parolasını argon2 ile saklıyor
D) Kalıcılık (persistence); zararlı her açılışta yeniden çalışmayı hedefliyor
E) Veri sızdırma; dosyalar Run anahtarı üzerinden dışarı gönderiliyor

182. Bir e-ticaret firmasının SOC ekibinden Elvan, bir zararlının IP adresi yerine sürekli değişen alan adları üzerinden komuta sunucusuna ulaştığından şüpheleniyor. Hangi sürecin hangi alan adını çözdüğünü görmek için sunumdaki hangi Sysmon olayına bakmalıdır?

A) File Create
B) DNS Query
C) Registry Value Set
D) Process Create
E) Image Loaded (DLL)

183. Kampüs BT biriminde Sevil, Sysmon'u laboratuvar bilgisayarlarına kurarken hangi olayların kaydedileceğini nasıl seçeceğini ve kayıtların nereye yazılacağını soruyor. Sunuma göre doğru açıklama hangisidir?

A) Olaylar Wireshark display filter ile seçilir; kayıtlar yalnızca pcap dosyasına yazılır
B) Olaylar Nmap betikleriyle seçilir; kayıtlar yalnızca ekrana yazdırılıp silinir
C) Olaylar Burp Intruder ile seçilir; kayıtlar yalnızca tarayıcı geçmişine yazılır
D) Sysmon tüm olayları ayar yapılmadan kaydeder; kayıtlar yalnızca USB belleğe yazılır
E) Config XML ile seçilir; kayıtlar Sysmon/Operational günlüğüne yazılır

184. Bir muhasebe bilgisayarındaki olay akışını inceleyen Çağla şu süreç zincirini görüyor: winword.exe → cmd.exe → powershell.exe (kodlanmış bir komutla). Ardından aynı PowerShell süreci bilinmeyen bir IP'ye bağlanıyor. Sunuma göre bu tablonun doğru yorumu hangisidir?

A) Adımlar tek tek masum olabilir; zincir bütün olarak saldırı belirtisidir
B) Word'ün komut satırı açması normaldir; yalnızca IP adresi engellenip olay kapatılmalıdır
C) PowerShell bir Windows aracı olduğu için bu zincir hiçbir koşulda zararlı sayılmaz
D) Bu tablo yalnızca bir yazıcı sürücüsü güncellemesidir; EDR uyarısı yok sayılmalıdır
E) Zincir yalnızca imza veritabanında hash bulunursa zararlı kabul edilebilir

185. Bir bankanın çalışanına "fatura.pdf.exe" adlı bir e-posta eki geliyor; Windows'ta dosya uzantıları gizli olduğu için kullanıcı yalnızca "fatura.pdf" görüyor. Analist Bekir, dosyayı çalıştırmadan gerçekte ne olduğunu anlamak istiyor. Sunumdaki statik triyaj adımlarına göre ilk bakacağı sinyal hangisidir?

A) Dosyayı açıp PDF okuyucunun hata verip vermediğini görmek
B) file komutu ya da PE başlığıyla gerçek dosya türüne bakmak
C) Dosyanın adını değiştirip uzantıyı yalnızca .pdf yapmak
D) Dosyayı bir arkadaşına gönderip onun bilgisayarında denemek
E) Dosyayı Base64'e çevirip içeriğin okunabilir olup olmadığını görmek

186. Güvenlik dersinde Asuman, imza tabanlı ve davranış tabanlı tespiti karşılaştıran bir tablo hazırlıyor. Aşağıdaki ifadelerden hangisi sunuma göre imza tabanlı tespit için doğru DEĞİLDİR?

A) Dosyasız (fileless) saldırıları kolayca görür
B) Tek bayt değişince hash kaçar
C) 0-day zararlıyı çoğu zaman kaçırır
D) Hızlıdır ve az kaynak tüketir
E) Yanlış pozitif oranı düşüktür

187. Bir KOBİ, EDR'ın davranış tabanlı kurallarını devreye aldıktan sonra ilk haftada çok sayıda uyarı alıyor; bunların bir kısmı meşru yönetim betikleri çıkıyor. BT sorumlusu Utku yönetime durumu açıklıyor. Sunuma göre davranış tabanlı tespitin bu artı ve eksisi nasıl özetlenir?

A) Bilinmeyeni de yakalayabilir; ama daha çok yanlış pozitif üretir ve ayar ister
B) Yalnızca e-posta eklerini tarar; ama süreç zincirini hiç izleyemez
C) Yalnızca ağ trafiğine bakar; ama uç noktada hiçbir kaynak tüketmez
D) Yalnızca bilinen zararlıyı yakalar; ama hiç yanlış pozitif üretmez ve ayar istemez
E) Yalnızca hash eşleştirir; ama polimorfik zararlıyı her zaman yakalar

188. Bir EDR uyarısında Melda, “technique: T1059.001 — PowerShell (MITRE ATT&CK)” satırını görüyor. Yöneticisi bu etiketin ne işe yaradığını soruyor. Sunuma göre en doğru açıklama hangisidir?

A) Etiket, saldırganın kullandığı IP adresinin ülke koduna karşılık gelmektedir
B) Uyarı, PowerShell sürümünün güncel olmadığını ve yama gerektiğini göstermektedir
C) Davranış zinciri, saldırı tekniklerinin ortak kataloğundaki bir tekniğe eşlenmiştir
D) Uyarı, zararlının SHA-256 özetinin VirusTotal'daki tarama sonucunu göstermektedir
E) Etiket, PowerShell'in Microsoft tarafından kalıcı olarak kaldırıldığını bildirmektedir

189. Bir muhasebe bilgisayarı için EDR'dan CRITICAL seviyesinde uyarı geliyor: Word'den kodlanmış PowerShell başlatılmış ve süreç bilinmeyen bir IP'ye bağlanıyor. Konsolda “İzole et”, “Süreci sonlandır” ve “Yok say” seçenekleri var. Nöbetçi analist İlhan için ilk ve en uygun adım hangisidir?

A) Bilinmeyen IP'ye karşı geri tarama başlatmak
B) Kullanıcının parolasını değiştirip işi bitmiş saymak
C) Uyarıyı yok sayıp kullanıcıya e-postayla sormak
D) Makineyi biçimlendirip olay kayıtlarını silmek
E) Makineyi ağdan izole edip incelemeye başlamak

190. Bir SOC ekibine katılan Saliha'ya, şüpheli bir dosyayla karşılaştığında önce “çalıştırmadan inceleme”, gerekirse sonra “izole ortamda çalıştırıp gözlemleme” yapacağı anlatılıyor. Sunuma göre bu iki yaklaşım sırasıyla nasıl adlandırılır?

A) Hash'leme, ardından dijital imzalama
B) Dinamik analiz, ardından statik analiz
C) Port taraması, ardından paket yakalama
D) İmza tabanlı tespit, ardından NGAV
E) Statik analiz, ardından dinamik analiz

191. Bir analiz ortamında Tolgahan, şüpheli bir dosyanın strings çıktısında neredeyse hiç anlamlı metin bulamıyor; dosyanın büyük kısmı şifreli ya da paketlenmiş görünüyor. Sunuma göre dosyanın niyetini ortaya çıkarmak için hangi yaklaşım daha uygundur?

A) Dosyayı izole bir sandbox'ta çalıştırıp davranışını gözlemek (dinamik analiz)
B) Dosyayı kendi günlük bilgisayarında açıp ne yaptığını Görev Yöneticisi'nden izlemek
C) Hash değerini değiştirmek için dosyaya rastgele bayt eklemek
D) Dosyanın adını değiştirip uzantısını .txt yapıp açmak
E) strings komutunu daha kısa uzunlukla tekrar tekrar çalıştırmak

192. Bir belediyede staj yapan Rana, şüpheli bir e-posta ekini incelemek için kendi iş bilgisayarında açmayı düşünüyor; “Antivirüs zaten açık, bir şey olmaz” diyor. Sunumdaki kurala göre doğru uygulama hangisidir?

A) Antivirüs güncel ve açık olduğu sürece dosyayı iş bilgisayarında doğrudan açmak
B) İnternetten yalıtılmış, anlık görüntüsü alınmış bir analiz VM'i kullanmak
C) İş bilgisayarında açıp ardından tarayıcı geçmişini temizlemek
D) Dosyayı kurumun ortak dosya sunucusuna kopyalayıp orada açmak
E) Dosyayı açmadan önce iş bilgisayarının ekran parlaklığını düşürmek

193. Bir analiz ekibi, sandbox'ta çalıştırdığı bir örneğin hiçbir zararlı davranış göstermediğini, ancak aynı dosyanın gerçek bir kullanıcı bilgisayarında C2 bağlantısı kurduğunu fark ediyor. Ekipten Barkın, sunumdaki dinamik analiz notlarına göre bu durumu nasıl açıklamalıdır?

A) Dinamik analizde dosya hiç çalıştırılmadığı için davranış görülmez
B) Sandbox'ta çalışan dosyaların hash'i otomatik olarak değişir
C) Bazı zararlılar sandbox'ı fark edip davranışını gizleyebilir
D) Dinamik analiz yalnızca dosyanın adını ve boyutunu gösterebilir
E) Sandbox internete bağlı olduğu için dosya hemen silinmiş olmalıdır

194. Bir KOBİ'nin BT sorumlusu Hacer, şüpheli bir dosyayla karşılaştığında statik triyajın ilk adımını atmak istiyor. Sunumdaki dört sinyalden ilkine göre ne yapmalıdır?

A) Dosyayı Nmap ile tarayıp açık portlarını listelemek
B) Dosyayı AES ile şifreleyip arşive kaldırmak
C) SHA-256 özetini alıp bir itibar servisinde (ör. VirusTotal) sorgulamak
D) Dosyanın yanına bir dijital imza dosyası eklemek
E) Dosyayı çalıştırıp oluşan ağ trafiğini Wireshark ile ayrıntılı olarak izlemek

195. Analiz VM'inde Ersin, şüpheli bir dosyanın strings çıktısında şu satırları buluyor: bir http://203.0.113.77/gate.php adresi, Software\Microsoft\Windows\CurrentVersion\Run yolu ve zamanlanmış görev oluşturan bir komut. Sunuma göre bu bilgiler ne olarak adlandırılır ve nasıl kullanılır?

A) Hata mesajları; dosyanın bozuk olduğunu gösterip silmek için
B) Lisans anahtarları; yazılımın yasal olduğunu doğrulamak amacıyla
C) Uzlaşma göstergeleri (IOC); diğer makinelerde aramak ve paylaşmak için
D) Dijital imza; dosyanın güvenilir bir yayıncıdan geldiğini kanıtlamak için
E) Kullanıcı parolaları; hesapların kilidini açmak için kullanılmak üzere

196. Bir analiz raporunda Demet, şüpheli dosyanın import tablosunda WinHttpOpen gibi ağ bağlantısı kuran API'lerin yer aldığını yazıyor. Sunumdaki dördüncü triyaj sinyaline göre bu bilgi analiste ne söyler?

A) Dosyanın dijital olarak imzalandığını ve güvenilir olduğunu kanıtlar
B) Dosyanın yalnızca Linux sistemlerde çalışabileceğini gösterir
C) Dosyanın SHA-256 özetinin bilinen zararlılarla eşleştiğini kanıtlar
D) Dosyanın hangi yeteneklere sahip olduğunu, yani niyetini ele verir
E) Dosyanın hangi tarihte ve kim tarafından derlendiğini kesin olarak gösterir

197. Lab ödevinde Kubilay'dan bir test dosyasının SHA-256'sını alıp itibar servisinde sorgulaması isteniyor; kullanılacak dosya olarak EICAR veriliyor. Sunumdaki lab adımına göre EICAR'ın seçilme nedeni nedir?

A) Kendini her çalıştırmada değiştiren polimorfik bir zararlıdır
B) Zararsız bir test dosyasıdır; güvenlik ürünleri onu test amaçlı tanır
C) Yalnızca Linux'ta çalışan ve ağ bağlantısı kuran bir zararlıdır
D) Gerçek ve canlı bir fidye yazılımı olduğu için en gerçekçi örnektir
E) Hiçbir güvenlik ürünü tarafından tanınmadığı için gizli bir örnektir

198. Bir kampüs SOC'unun yeni kurulan uç nokta güvenliği sürecini anlatan Filiz, sunumdaki “bütünü birleştir” slaytındaki üç adımı doğru sırayla sıralamak istiyor. Doğru sıra hangisidir?

A) Topla (Sysmon) → Çöz (statik analiz) → Tespit et (EDR)
B) Tespit et (EDR) → Çöz (statik analiz) → Topla (Sysmon)
C) Çöz (statik analiz) → Topla (Sysmon) → Tespit et (EDR)
D) Topla (Sysmon) → Tespit et (EDR) → Çöz (statik analiz)
E) Tespit et (EDR) → Topla (Sysmon) → Çöz (statik analiz)

199. Bir hastanenin yöneticisi, tüm bilgisayarlara EDR kurulduktan sonra “Artık güvenlik tamam, başka bir şeye gerek yok” diyor. BT sorumlusu Anıl, sunumun kapanış notuna dayanarak itiraz ediyor. Anıl'ın gerekçesi hangisidir?

A) Tek araç yetmez; telemetri SIEM'e akmalı, olay müdahale süreciyle birleşmelidir
B) EDR yalnızca Linux sunucularda çalıştığı için kurumdaki Windows bilgisayarları korumaz
C) EDR kurulduğunda Sysmon ve antivirüs otomatik olarak devre dışı kalır
D) EDR uyarıları yasal olarak yalnızca polis tarafından incelenebilir
E) EDR yalnızca ağ trafiğini izler; uç noktada çalışan süreçleri hiç göremez

200. Bir analiz ekibinde Tufan, şüpheli bir dosya için yapılacak işlerin listesini “statik” ve “dinamik” olarak ayırıyor. Aşağıdakilerden hangisi sunumdaki statik analiz adımları arasında YER ALMAZ?

A) SHA-256 özetini itibar servisinde sorgulamak
B) file komutuyla gerçek dosya türünü belirlemek
C) strings ile gömülü URL ve IP'leri çıkarmak
D) Import tablosundaki API çağrılarını okumak
E) Dosyayı sandbox'ta çalıştırıp ağ trafiğini izlemek